IMPLEMENTATION_PLAN.md: CareGrid SA

0. Plan details

Field	Value
App name	CareGrid SA
Built from PRD version	v1.0(
Screen designs	https://stitch.withgoogle.com/projects/11536583139923150484
Status	Ready to build
Last updated	04 Nov 2026

1. Start here (instructions for the coding agent)

Before writing any code:

1. Read this whole file from top to bottom.
2. Read `docs/PRD.pdf`.
3. Look at the screen designs listed in Section 7.3.
4. Check Section 18. If any clarification is still open stop and ask the human. Do not start.
5. Check that the prerequisites in Section 4.2 are installed.
6. Start **Phase 1 only**. Follow Section 2 at all times.

2. Rules for the coding agent (copy word for word, do not edit)

1. **One phase at a time.** Only work on the phase the human asked for. When that phase's Definition of Done is complete, stop and wait for the human to say "Start Phase <number>".

2. **Test-driven development (TDD) for every task.** Follow the cycle in Section 12.1:

- Write the test.
- Run it and see it fail for the right reason.
- Write the smallest code that makes it pass.
- Run all tests.
- Refactor while all tests still pass.

3. **Never cheat a test.** Never delete, skip, weaken or change a test just to make it pass. If you believe a test is wrong, stop and explain why to the human.

4. **Never break earlier work.** Every test from earlier phases must still pass before a phase is done.

5. **Build only what is planned.** Build only what is in this file and `docs/PRD.md`. Never build anything in Section 3.3 (Deferred).

6. **Ask, don't guess.** If anything is missing, unclear or contradictory, stop, add it to Section 18, and ask the human.

7. **Match the designs.** Every screen must match its design in Section 7.3: layout, order, labels, text, colours and spacing. Use the design tokens in Section 7.1. Never hard-code colours, font sizes or spacing.

8. **Every state, every screen.** Each screen must handle every state listed for it in Section 7.3 (chosen from normal, empty, loading, error, offline, success, plus any screen-specific states).

9. **Exact wording.** Use the exact labels and messages from the PRD. Never invent wording.

10. **Security first.**

- Never put secret keys in app code, logs, test files or Git.
- Every permission rule in Section 9 must be enforced on the server or database, never only in the app.
- Every permission rule must have a test.

11. **Full check before "done".** Run the full check command (Section 4.3) before saying a phase is done, then add a short summary of the results to the Progress log (Section 17).

12. **Record your progress.** After each phase:

- tick the checkboxes for that phase in this file;
- add a row to the Progress log;
- commit using the commit message given in the phase.

13. **No surprise libraries.** Do not add, remove or upgrade any library or tool not listed in Section 4.1 without asking the human first.

14. **Stuck rule.** If the same problem is still failing after 3 attempts, stop and report:

- what you tried;
- the exact error;
- what you need from the human.

15. **Clean code.** Follow the folder structure in Section 5. Use the PRD's key terms (Section 3.4) for names in code. Keep files small and focused.

3. Project summary and scope

3.1 Summary

CareGrid SA helps South African healthcare workers track stress and share peer support so that they reduce burnout safely. Clinicians register with a hashed professional verification token to stay anonymous, log shift stress in under 30 seconds, debrief in moderated role-based Peer

Circles, and reach South African crisis helplines with one tap. Facility-level reporting is deferred; admin work is done in the Supabase console.

Platform: Web app, built as a Progressive Web App (PWA), designed mobile-first at 360px width.

3.2 Features in scope

ID	Feature	Priority	Built in phase
F1	Authentication and Anonymity (sign up with token, log in, reset password, delete account)	Must	3
F2	Shift-Stress Check-In (1 to 5 stress score, shift type, note, daily reminder)	Must	4
F3	Peer Circles (view circles, read posts, post debriefs, reply, reply notifications)	Must	5
F4	Crisis and SOS Directory (SOS drawer, tap-to-call links, resources list)	Must	4
F5	Personal Wellness Log (7-day stress chart and daily streak on S6)	Should	6

Offline support, accessibility, performance and edge cases are quality requirements (PRD 12.1) built in Phase 7. They are not separate features.

3.3 Deferred: do NOT build

- 1-on-1 direct messaging (PRD non-goal).
- Video conferencing or audio calls (PRD non-goal).
- Patient records or clinical triage (PRD non-goal).
- Native mobile app builds or app store releases (PRD non-goal; PWA only).
- Admin web analytics dashboard, the Pulse Dashboard and any admin screen, including A1 (PRD future feature; admin work stays in the Supabase console).
- Automated EAP appointment booking (PRD future feature).

- Audio voice note debriefing in Peer Circles (PRD future feature).
- Post reporting button and automated keyword flagging (moved from PRD 13.2 to Deferred; see Section 18, question 6).
- Editing posts or replies, and a delete button for posts or replies (the database allows the author to delete; there is no screen for it in v1).
- Pagination or infinite scroll in feeds (each feed loads its latest 50 items).
- Dark mode (PRD 9.1: not in v1).
- Languages other than English (South Africa).
- Push notifications, email notifications and any background scheduler.
- Any third-party service other than Supabase and Vercel.

3.4 Key terms (use these names in code)

Term (PRD 1.7)	Name in code	Meaning
Peer Circle	`circle_name` on `posts` (values `Nursing`, `Medical`, `EMS`, `General`)	A role-focused discussion channel where clinicians post anonymous text debriefs
Post (debrief)	`Post`, table `posts`	One anonymous debrief in a Peer Circle
Reply	`Reply`, table `replies`	One anonymous reply to a post
Check-In	`CheckIn`, table `check_ins`	A 30-second log of shift stress score (1 to 5), shift type and optional note
SOS Drawer	`SosDrawer` (modal M2)	A slide-up panel with direct phone links to crisis helplines
Handle	`handle` on `profiles`	The anonymous display name: Peer, role, 3 digits (for example Peer-Nurse-402)
Ghost-User	`GHOST_USER_ID`, a fixed row in `profiles`	The system profile that takes over authorship when an account is deleted (BR5)
Professional token	`token_hash` on `profiles`	The SHA-256 hash of the HPCSA or SANC registration number; the plain value is never stored
Pulse Dashboard	Not built in v1	Aggregated anonymous reporting screen for coordinators (Deferred, A1)

4. Tech stack, prerequisites and commands

4.1 Stack

Versions are "latest stable at setup". The agent records the exact versions in Section 17 after Phase 1.

Layer	Tool	Version	Used for
Frontend	React + Vite	Latest stable at setup	Single-page PWA, mobile-first at 360px
Routing	React Router	Latest stable at setup	Screen routes and route guards (Section 11)
Language	TypeScript	Latest stable at setup	Type safety for data models
Styling	Tailwind CSS	Latest stable at setup	Utility styling driven by the design tokens in Section 7.1
Icons and font	Lucide React, `@fontsource/inter`	Latest stable at setup	Lucide icon set and Inter, served from the app (no external font request)
PWA	`vite-plugin-pwa`	Latest stable at setup	Web manifest, service worker, offline app shell
Backend and database	Supabase: PostgreSQL, Auth, Row-Level Security	Latest stable at setup (local via Supabase CLI)	Accounts, tables, permission rules, triggers
Server functions	Supabase Edge Functions (Deno)	Latest stable at setup	`signup` and `delete-account` (the only code that uses the secret key)
Data fetching and caching	None (supabase-js client only)	Latest stable at setup	Direct calls to Supabase; no extra caching library
Unit and component tests	Vitest, React Testing Library, user-event, jsdom,	Latest stable at setup	Business rules and screens with fake data

	`@vitest/coverage-v8`		
Database and permission tests	pgTAP via `supabase test db`	Bundled with Supabase CLI	Constraints, triggers, permission rules
Integration tests	Vitest + supabase-js against the local backend	Latest stable at setup	Each backend operation, including both Edge Functions
End-to-end tests	Playwright (Chromium, 360px mobile viewport)	Latest stable at setup	Whole user flows in a real browser
Lint and type check	ESLint, TypeScript compiler (`tsc`)	Latest stable at setup	Code quality gates
Scripts	Plain Node `.mjs` scripts in `scripts/`	Node LTS	Seed users, secret scan, bundle size check
Build and hosting	Vercel (frontend), Supabase hosted project (backend)	Current	Deployment and demo link

4.2 Prerequisites on the computer

- Node.js (current LTS) and npm
- Git, with a GitHub account and access to https://github.com/noluforge/caregrid-sa
- Docker Desktop, running (needed by the local Supabase stack)
- Google Chrome (for Playwright and DevTools device mode) and an Android phone with Chrome for real-device checks
- Playwright browser installed: `npx playwright install chromium`
- A Supabase account (hosted project created in Phase 8)
- A Vercel account linked to the GitHub repository (used in Phase 8)

4.3 Commands

The Supabase CLI is run through `npx supabase`, so it is not a global install.

Before the full check, these must already be running: the local backend (`npx supabase start`) and the Edge Functions server (`npm run functions:serve`). End-to-end tests start the app themselves and are not part of the full check; run them in Step 4 of each feature phase.

Purpose	Command
Install dependencies	`npm install`
Start the local backend (Postgres, Auth, local	`npx supabase start`

email inbox)	
Serve the Edge Functions locally	`npm run functions:serve`
Reset the database (migrations + seed data + seed users)	`npm run db:reset`
Start the app	`npm run dev`
Unit and component tests	`npm run test:unit`
Database and permission tests	`npm run test:db`
Integration tests	`npm run test:integration`
End-to-end tests	`npm run test:e2e`
Lint	`npm run lint`
Type check	`npm run typecheck`
Secret scan	`npm run scan:secrets`
Full check (run before every "done")	`npm run check` (runs lint, type check, secret scan, unit and component, database, integration)
Build for release	`npm run build`

5. Folder structure

```
caregrid-sa/
  src/
    main.tsx                      app entry, registers the service worker
    App.tsx                       router, session provider, toast provider
    routes/
      AppRoutes.tsx               all routes from Section 11
      guards.tsx                  logged-in and logged-out route guards
    theme/
      tokens.ts                   design tokens (Section 7.1), the only place with
colours, sizes, spacing
    components/                   shared components (Section 7.2), one file each
      Button.tsx  TextField.tsx  TextArea.tsx  SelectField.tsx  Banner.tsx
Toast.tsx
      Header.tsx  TabBar.tsx  Skeleton.tsx  RatingSelector.tsx  ResourceCard.tsx
      PostCard.tsx  StressTrendChart.tsx  SosDrawer.tsx (M2)
DeleteAccountModal.tsx (M1)
    screens/                      one file per screen
      S1Welcome.tsx  S2SignUp.tsx  S3LogIn.tsx  S4ForgotPassword.tsx
```

```
S5CheckIn.tsx
      S6Home.tsx  S7PeerCircles.tsx  S8CircleFeed.tsx  S9NewPost.tsx
      S10Resources.tsx  S11Profile.tsx  S12PostDetail.tsx
    lib/
      supabase.ts                 the single Supabase client (public anon key
only)
      session.ts                  session provider, 14-day session limit
      offlineQueue.ts             LocalStorage queue for offline check-ins and
post drafts
      format.ts                   date (27 Oct 2026), SAST time, phone (+27)
formatting
      messages.ts                 every exact message from Section 10 and PRD 12.2
      rules/                      pure business-rule functions
        checkIn.ts  handle.ts  token.ts  password.ts  post.ts  sos.ts  streak.ts
    data/
      resources.ts                crisis directory entries and tel: numbers
(single source for M2 and S10)
    hooks/                        data hooks, one per operation group
  supabase/
    config.toml                   Auth settings (email confirmation on, 1-hour
reset link)
    migrations/                   SQL migrations (Section 8.6)
    seed.sql                      sample data (Section 8.7)
    functions/
      signup/index.ts             OP1
      delete-account/index.ts     OP6
    tests/database/               pgTAP tests (.test.sql)
  scripts/
    seed-users.mjs                creates the seeded auth users
    scan-secrets.mjs              secret scan (working tree, and history with --
history)
    check-bundle-size.mjs         route bundle size check (T-NFR-2)
  tests/
    unit/                         pure rules
    component/                    components and screens with fake data
    integration/                  operations against the local backend
    e2e/                          Playwright flows
    helpers/                      fake data from PRD 8.4, test user sign-in
helpers
  public/                         icons, logo exported from the designs, manifest
assets, privacy.html (text written by the human)
  docs/
    PRD.md
    designs/                      exported screen designs (Section 7.3)
  IMPLEMENTATION_PLAN.md
  .env.example
  .gitignore
```

```
README.md
```

Rule: a new folder may only be created if it is added to this section first.

6. Environment variables and secrets

Name	What it is	Where to get it	Public or secret	Used by
`VITE_SUPABASE_URL`	Supabase API URL	Supabase dashboard (hosted) or `npx supabase status` (local)	Public	App, integration tests, scripts
`VITE_SUPABASE_ANON_KEY`	Supabase anon (public) key; safe in the browser because Row-Level Security protects the data	Supabase dashboard or `npx supabase status`	Public	App, integration tests
`SUPABASE_SERVICE_ROLE_KEY`	Supabase secret key that bypasses all permission rules	Supabase dashboard or `npx supabase status`	Secret	Edge Functions (provided by Supabase at runtime), scripts and integration tests only. Never the app
`TEST_USER_PASSWORD`	Password given to the seeded test accounts	You choose it (the PRD test value Password123	Secret	Seed script and tests only; never used on the

	may be used locally only)	hosted project

`.env.example` (committed to Git, placeholder values only):

```
VITE_SUPABASE_URL=http://127.0.0.1:54321
VITE_SUPABASE_ANON_KEY=replace-with-local-anon-key
SUPABASE_SERVICE_ROLE_KEY=replace-with-local-service-role-key
TEST_USER_PASSWORD=replace-with-a-local-test-password
```

Rules:

- Real values go in `.env`, which is listed in `.gitignore` and never committed.
- The app never imports `SUPABASE_SERVICE_ROLE_KEY`. Only variables that start with `VITE_` may be read in `src/`.
- On a phone, `127.0.0.1` is the phone itself. When testing on a real phone against the local backend, use your computer's Wi-Fi IP address in `VITE_SUPABASE_URL`. The hosted deployment uses the Supabase project URL.
- Vercel gets only `VITE_SUPABASE_URL` and `VITE_SUPABASE_ANON_KEY`. The service role key is never added to Vercel.
- If a new variable is needed, add it here and to `.env.example` first.

7. Design system and screens

7.1 Design tokens

All values live in `src/theme/tokens.ts` and are mapped into the Tailwind config. Screens and components use tokens only.

Token	Value	From PRD
`color.primary`	#0B7A6B (Deep Teal)	9.1 Primary colour
`color.accent`	#E8F5E9 (Soft Sage)	9.1 Secondary / accent colour
`color.background`	#F8FAFC (Clean Off-White)	9.1 Background colour
`color.text`	#1E293B (Dark Slate)	9.1 Main text colour
`color.error` (also SOS)	#DC2626 (Emergency Red)	9.1 Error / SOS colour
`color.surface`	#FFFFFF	9.1 (cards and inputs sit on white, the contrast base for 4.5:1)

`color.onPrimary`	#FFFFFF	9.1 (text on primary and error buttons)
`color.toast`	#1E293B (same as `color.text`)	8.3 Toast ("dark floating banner")
`font.family`	Inter	9.1 Font
`font.size.title`	22px, bold	9.1 Text sizes
`font.size.subheading`	18px, semibold	9.1
`font.size.body`	16px, regular	9.1
`font.size.caption`	12px, regular	9.1
`font.size.button`	16px, bold	8.3 Primary Button
`space.1` / `space.2` / `space.3`	8px / 16px / 24px	9.1 Spacing unit (8px grid)
`space.margin`	16px (screen side margin)	9.1
`radius.button`	8px	9.1 Corner radius
`radius.card`	12px	9.1
`size.touchMin`	44px	9.4
`size.viewport`	360px (design width)	1.5, 9.3
`icon.set`	Lucide	9.1 Icon set

No other colours are allowed. Borders use `color.accent`. Dark mode is not built.

7.2 Shared components

Component	File	Variants and states	Used on	Tests
Button	`components/Button.tsx`	primary (full width, 8px radius, 16px bold), secondary, danger (`color.error`); disabled; loading (spinner and label)	S1 to S5, S9, S11, M1	T-C-1

TextField	`components/TextField.tsx`	text, email, password (show/hide); normal, error (red border and message under the field), disabled	S2, S3, S4	T-C-2
TextArea	`components/TextArea.tsx`	optional character counter, max length, counter turns red over limit	S5, S9, S12	T-C-3
SelectField	`components/SelectField.tsx`	dropdown with label; normal, error	S2 (Role), S5 (Shift Type)	T-C-4
Banner	`components/Banner.tsx`	info, warning, error, offline; optional action	S1, S3, S5, S6, S7, S10	T-C-5
Toast	`components/Toast.tsx`	dark floating banner, slides from top, auto-dismisses after 3 seconds	S4, S5, S6, S9, S11	T-C-6
Header	`components/Header.tsx`	logo, screen title, optional back arrow or cancel, persistent red SOS icon (logged-in screens only); tapping SOS opens	All screens	T-C-7

		M2		
TabBar	`components/TabBar.tsx`	4 icons: Home, Circles, Resources, Profile; active state highlighted; fixed to the bottom above browser chrome	S6, S7, S8, S10, S11	T-C-8
Skeleton	`components/Skeleton.tsx`	card and list-row skeletons	S6, S7, S8, S12	T-C-9
RatingSelector	`components/RatingSelector.tsx`	buttons 1 to 5 (1 = Calm, 5 = Extreme Stress); one selected; each at least 44x44px	S5	T-C-10
ResourceCard	`components/ResourceCard.tsx`	name, description, optional call button with `tel:` link	S10, M2	T-C-11
PostCard	`components/PostCard.tsx`	handle, circle, timestamp, content (links shown as plain text), reply count	S6, S8, S12	T-C-12
StressTrendChart	`components/StressTrendChart.tsx`	7-day bar chart drawn with simple SVG (no chart library); empty variant	S6	T-C-13
SosDrawer (M2)	`components/SosDrawer.tsx`	bottom sheet;	Opene	T-

		normal; alert variant with the line "We care about your safety. Tap to call SADAG instantly."	d from Header, S5, S10	M2-1 to T-M2-3
DeleteAccountModal (M1)	`components/DeleteAccountModal.tsx`	normal, processing	S11	T-M1-1, T-M1-2

7.3 Screens

Design files are the exported Stitch screens in `docs/designs/`. The design for S12 and the updated S2 (Role dropdown) and S4 (Set new password mode) must be generated with the Stitch prompts in PRD_v1.1_CHANGES.md and exported before the phase that builds them (S2 and S4 before Phase 3, S12 before Phase 5).

ID	Screen	Route / file	Design	Who can open it (else redirect to)	Tab bar	Required states	Phase
S1	Welcome	screens/S1Welcome.tsx`	`docs/designs/S1-welcome.png`	Logged out (else S6)	No	Normal, Offline	1 (offline banner wired in 7)
S2	Sign Up	screens/S2SignUp.tsx`	`docs/designs/S2-sign-up.png`	Logged out (else S6)	No	Normal, Error, Loading	3
S3	Log In	screens/S3LogIn.tsx`	`docs/designs/S3-log-in.png`	Logged out (else S6)	No	Normal, Error, Account Locked	3
S4	Forgot Password	`/forgot-password` and `/reset-password`, `screens/S4ForgotPasswo	`docs/designs/S4-forgot-password.pn	Logged out for	No	Normal, Success (both	3

	(and Set new password mode)	rd.tsx`	g`	`/forgot-password` (else S6). `/reset-password` needs the email recovery link		modes), Error (set-password mode)	
S5	Stress Check-In	check-in`, screens/S5CheckIn.tsx`	`docs/designs/S5-check-in.png`	Logged in (else S1)	No	Normal, Restricted, High Alert	4
S6	Home Dashboard	home`, screens/S6Home.tsx`	`docs/designs/S6-home-dashboard.png`	Logged in (else S1)	Yes	Normal, Empty, Loading, Offline	4 (shell), 5 (activity and reply notifications), 6 (chart, streak, Empty)
S7	Peer Circles List	circles`, screens/S7PeerCircles.tsx	`docs/designs/S7-peer-circles.png`	Logged in (else S1)	Yes	Normal, Loading, Empty	5
S8	Circle Feed	circles/:circle`, screens/S8CircleFeed.tsx`	`docs/designs/S8-circle-feed.png`	Logged in (else S1)	Yes (Circles active)	Normal, Empty, Loading	5
S9	New Post	circles/:circle/new`, screens/S9NewPost.tsx`	`docs/designs/S9-new-post.png`	Logged in (else S1)	No	Normal, Error, Publishing	5

S10	Resources and SOS	`/resources`, `screens/S10Resources.tsx`	`docs/designs/S10-resources.png`	Logged in (else S1)	Yes	Normal, Offline	4 (offline in 7)
S11	Profile and Settings	`/profile`, `screens/S11Profile.tsx`	`docs/designs/S11-profile-settings.png`	Logged in (else S1)	Yes	Normal	3
S12	Post Detail	`/posts/:postId`, `screens/S12PostDetail.tsx`	`docs/designs/S12-post-detail.png`	Logged in (else S1)	No	Normal, Loading, Unavailable	5
M1	Delete Account modal	Overlay on S11, `components/DeleteAccountModal.tsx`	`docs/designs/M1-delete-account.png`	Logged in	No	Normal, Processing	3
M2	Emergency SOS Drawer	Overlay on any logged-in screen, `components/SosDrawer.tsx`	`docs/designs/M2-sos-drawer.png`	Logged in	No	Normal	4

Resource directory data (`src/data/resources.ts`, the single source for M2 and S10):

Entry	Shown on	Number (display / `tel:`)
SADAG 24/7 Helpline	M2 card 1, S10	0800 567 567 / `tel:0800567567`
SADAG Mental Health Helpline (labelled "Healthcare EAP Crisis Line" in PRD v1.0; see Section 18, question 20)	M2 card 2	0800 212 223 / `tel:0800212223`
EAP Services	S10	Information card, no number: "Contact your facility's Employee Assistance Programme."
Netcare Helpline	S10	082 911 / `tel:082911`
Legal Advisory	S10	Information card, no number (see Section 18, question 20)

8. Data model and database

8.1 Tables

Types follow PRD 10.1. Every PRD rule is a database constraint. All timestamps are `timestamptz`; the app shows them in SAST (Africa/Johannesburg).

Table: `profiles`: one row per clinician (plus one system row, Ghost-User). The email address is kept only in Supabase Auth (`auth.users`) and is not copied here (Section 18, question 9). `id` equals the Supabase Auth user id. There is no foreign key to `auth.users` so the Ghost-User row can exist without a login.

Column	Type	Null?	Default	Constraints	Notes
id	uuid	No	none (set by the `signup` function to the auth user id)	primary key	
token_hash	text	No	none	unique; check: exactly 64 lowercase hexadecimal characters	BR2. SHA-256 of the token. Not readable by the app (column permission)
handle	text	No	none	unique; length 30 or less; check: matches Peer, role, 3 digits (for example Peer-Nurse-402), or equals Ghost-User	BR2
role	text	No	Nurse	check: one of Nurse, Doctor, EMS, Admin, Ghost	Ghost is used only by the system row. Admin is set in the Supabase console

reminder_enabled	boolean	No	true		Daily reminder preference (S11)
reply_alerts_enabled	boolean	No	true		Reply alert preference (S11)
created_at	timestamptz	No	now()		

Table: `check_ins`: one daily stress log.

Column	Type	Null?	Default	Constraints	Notes
id	uuid	No	generated	primary key	
user_id	uuid	No	`auth.uid()`	foreign key → profiles(id) on delete cascade	
stress_score	integer	No	none	check: 1 to 5	BR1, BR4
shift_type	text	No	Day	check: one of Day, Night, Overtime	UI labels: Day Shift, Night Shift, Overtime
note	text	Yes	none	check: 300 characters or fewer	
created_at	timestamptz	No	now()		BR1 interval is measured on this column

Table: `posts`: one anonymous Peer Circle debrief.

Column	Type	Null?	Default	Constraints	Notes
id	uuid	No	generated	primary key	
author_id	uuid	No	`auth.uid()`	foreign key → profiles(id) on delete restrict	BR5: reassigned to the Ghost-User id before an

					account is purged
author_handle	text	No	set by trigger	length 30 or less	Copy of the author's handle, set by a trigger so other users never need to read `profiles`
circle_name	text	No	General	check: one of Nursing, Medical, EMS, General	
content	text	No	none	check: 10 to 1,000 characters after trimming	BR3
created_at	timestamptz	No	now()		

Table: `replies`: one anonymous reply to a post.

Column	Type	Null?	Default	Constraints	Notes
id	uuid	No	generated	primary key	
post_id	uuid	No	none	foreign key → posts(id) on delete cascade	
author_id	uuid	No	`auth.uid()`	foreign key → profiles(id) on delete restrict	BR5
author_handle	text	No	set by trigger	length 30 or less	As on posts
content	text	No	none	check: 10 to 1,000 characters after	BR3 (same rule as posts)

				trimming	
created_at	timestamptz	No	now()		

Table: `notifications`: one in-app reply alert.

Column	Type	Null?	Default	Constraints	Notes
id	uuid	No	generated	primary key	
user_id	uuid	No	none	foreign key → profiles(id) on delete cascade	The post owner
type	text	No	reply	check: equals reply	
post_id	uuid	No	none	foreign key → posts(id) on delete cascade	
reply_id	uuid	No	none	foreign key → replies(id) on delete cascade	
read_at	timestamptz	Yes	none		Set when the owner opens the post from the alert
created_at	timestamptz	No	now()		

View: `circle_stats` (read-only, runs with the caller's permissions): one row for each of the four circles with `circle_name`, `active_members` (distinct authors of posts or replies in that circle in the last 30 days, excluding Ghost-User) and `last_post_at`. All four circles appear even with no posts.

Circle display names (used by the app, stored nowhere): Nursing = "Nursing Debriefs", Medical = "Doctors Forum", EMS = "EMS Emergency Room", General = "General Wellness". Route values: `nursing`, `medical`, `ems`, `general`. The S9 line reads "Posting in" + circle_name + "Circle" (for example "Posting in Nursing Circle").

8.2 Relationships and delete behaviour

- One profile has many `check_ins`: `check_ins.user_id` → `profiles.id`, on delete cascade.

- One profile creates many `posts` and `replies`: `author_id` → `profiles.id`, on delete restrict. The `purge_user_data` function first reassigns `author_id` (and `author_handle`) to Ghost-User, then deletes the profile (BR5).
- One post has many `replies`: `replies.post_id` → `posts.id`, on delete cascade.
- One circle (the `circle_name` value) contains many posts.
- One profile has many `notifications`: on delete cascade. Notifications also cascade when their post or reply is deleted.
- Ghost-User is the profile with id `00000000-0000-0000-0000-000000000000`, handle `Ghost-User`, role `Ghost`, created by migration. It has no login and no token (its `token_hash` is the hash of a fixed internal string).

8.3 Status changes

Table.column	From	To	Triggered by	Enforced by
check_ins.stress_score	any value 1 to 4	5	User submits a check-in with score 5 (BR4)	Rule function `shouldShowSos` in `lib/rules/sos.ts` (app behaviour, unit tested); the database only stores the score
notifications.read_at	empty	a timestamp	Owner opens the post from the alert on S6	Update policy, owner only (SEC13)
profiles (row)	exists	purged	User confirms deletion on M1 (BR5)	`purge_user_data` function, called only by the `delete-account` Edge Function

8.4 Indexes

- `check_ins (user_id, created_at desc)` for the BR1 interval check, last check-in and the 7-day chart.
- `posts (circle_name, created_at desc)` for each circle feed and `circle_stats`.
- `posts (author_id, created_at desc)` for the BR3 hourly limit.
- `replies (post_id, created_at)` for post detail.
- `replies (author_id, created_at desc)` for the BR3 hourly limit on replies.
- `notifications (user_id, read_at, created_at desc)` for unread alerts on S6.
- `profiles (token_hash)` and `profiles (handle)` are covered by their unique constraints.

8.5 Automatic jobs and triggers

Name	Runs when	What it does	BR#	Test
`trg_check_ins_interval`	Before insert on `check_ins`	Rejects the row with the error code CHECKIN_TOO_SOON if the same user has a check-in in the last 8 hours	BR1	T-BR1-2, T-BR1-3
`trg_posts_before_insert`	Before insert on `posts`	Sets `author_handle` from `profiles`; rejects with POST_RATE_LIMIT if the author already has 5 posts in the last hour	BR3	T-BR3-3
`trg_replies_before_insert`	Before insert on `replies`	Sets `author_handle`; rejects with REPLY_RATE_LIMIT if the author already has 5 replies in the last hour	BR3	T-BR3-5
`trg_replies_notify`	After insert on `replies`	Creates a `notifications` row for the post owner unless the owner wrote the reply, is Ghost-User, or has `reply_alerts_enabled` false	F3	T-DB-13
`purge_user_data(uuid)`	Called by `delete-account` only	Deletes the user's check-ins and notifications, reassigns posts and replies to Ghost-User, deletes the profile	BR5	T-BR5-1 to T-BR5-3

There are no scheduled jobs. The 18:00 reminder is calculated in the app (Section 10, OP7).

8.6 Migrations (in order)

1. `20261105000100_profiles.sql`: `profiles` table, constraints, Ghost-User row, column permissions (users may read only their own non-secret columns and update only the two preference columns).

2. `20261105000200_check_ins.sql`: `check_ins` table, constraints, index, `trg_check_ins_interval`.

3. `20261105000300_posts_replies.sql`: `posts` and `replies` tables, constraints, indexes, `trg_posts_before_insert`, `trg_replies_before_insert`.

4. `20261105000400_notifications.sql`: `notifications` table, index, `trg_replies_notify`.

5. `20261105000500_circle_stats.sql`: `circle_stats` view.

6. `20261105000600_rls_policies.sql`: enable Row-Level Security on every table and create every policy in Section 9.

7. `20261105000700_purge_user_data.sql`: `purge_user_data` function, executable only by the service role.

8.7 Seed data and test accounts

- **Seed file:** `supabase/seed.sql`. It loads the PRD 8.4 sample data set: three profiles (Peer-Nurse-402, Peer-Doctor-118, Peer-EMS-089) with fixed ids, one test Admin profile (Peer-Admin-001), 3 posts in the Nursing circle and 2 posts in the EMS circle. Post texts are 5 neutral sample debriefs of 10 to 200 characters with no real or medical details. Seed tokens are fake strings hashed with SHA-256 inside the seed file.
- **Seed users:** `scripts/seed-users.mjs` runs after the seed file (inside `npm run db:reset`) and creates the matching Supabase Auth users with the same ids, already email-verified, using `SUPABASE_SERVICE_ROLE_KEY`.
- **Test accounts:** `nurse.test@caregrid.co.za` (Peer-Nurse-402), `doctor.test@caregrid.co.za` (Peer-Doctor-118), `ems.test@caregrid.co.za` (Peer-EMS-089), `admin.test@caregrid.co.za` (Peer-Admin-001, role Admin). Passwords come from `TEST_USER_PASSWORD`. Never write them in this file.
- No seeded check-ins: tests create their own so the BR1 interval never blocks them.

9. Security and permissions

Row-Level Security (RLS) is switched on for every table. The `authenticated` role is a signed-in user; `anon` is someone not signed in. There are no admin policies: admin work uses the Supabase console, which bypasses RLS.

ID	Table / resource	Action	Who is allowed	Rule	Enforced by	Tests (allow / deny)
SEC 1	profiles	read	Owner only	`id = auth.uid()`; `token_hash` column is not readable by any app role	Policy `profiles_select_own` and column permissions	T-SEC-1a / T-SEC-1b

SEC 2	profiles	update	Owner only	Only `reminder_enabled` and `reply_alerts_enabled` can change; `role`, `handle`, `token_hash` cannot	Policy `profiles_update_own` and column permissions	T-SEC-2a / T-SEC-2b
SEC 3	profiles	insert, delete	Nobody in the app (service role only)	No insert or delete policy for `authenticated` or `anon`	No policy (default deny)	T-SEC-3a (service role path works) / T-SEC-3b (user insert and delete refused)
SEC 4	check_ins	read	Owner only	`user_id = auth.uid()`	Policy `check_ins_select_own`	T-SEC-4a / T-SEC-4b
SEC 5	check_ins	create	Owner only	`user_id = auth.uid()`	Policy `check_ins_insert_own`	T-SEC-5a / T-SEC-5b
SEC 6	check_ins	update, delete	Nobody in the app (account deletion only)	No update or delete policy	No policy	T-SEC-6a (purge function removes rows) / T-SEC-6b (user update and delete refused)
SEC 7	posts	read	Any signed-in user	`auth.uid()` is not null	Policy `posts_select_authenticated`	T-SEC-7a / T-SEC-7b (anon refused)
SEC 8	posts	create	Author only	`author_id = auth.uid()`	Policy `posts_insert_own`	T-SEC-8a / T-SEC-8b (cannot

						post as someone else)
SEC 9	posts	delete	Author only	`author_id = auth.uid()`	Policy `posts_delete_own`	T-SEC-9a / T-SEC-9b (Sipho cannot delete Thandiwe's post)
SEC 10	replies	read	Any signed-in user	`auth.uid()` is not null	Policy `replies_select_authenticated`	T-SEC-10a / T-SEC-10b
SEC 11	replies	create	Author only	`author_id = auth.uid()`	Policy `replies_insert_own`	T-SEC-11a / T-SEC-11b
SEC 12	replies	delete	Author only	`author_id = auth.uid()`	Policy `replies_delete_own`	T-SEC-12a / T-SEC-12b
SEC 13	notifications	read, update (mark read)	Owner only	`user_id = auth.uid()`	Policies `notifications_select_own`, `notifications_update_own`	T-SEC-13a / T-SEC-13b
SEC 14	notifications	insert	Nobody in the app (trigger only)	No insert policy; the trigger runs with elevated rights	Trigger `trg_replies_notify`	T-SEC-14a (trigger creates a row) / T-SEC-14b (user insert refused)
SEC 15	All tables	Admin role limits	Admin users	An Admin clinician account has no extra access: it cannot read other users' check-ins or unmask	Same policies as every other user	T-SEC-15a (Admin reads own check-ins) / T-SEC-15b

				`token_hash`		(Admin cannot read another user's check-ins or token_hash)
SEC 16	`delete-account` function	call	A signed-in user, for their own account only	The user id comes from the verified token, never from the request body	Edge Function reads the user from the JWT	T-SEC-16a / T-SEC-16b (no token: refused)
SEC 17	`purge_user_data` function	execute	Service role only	Not executable by `anon` or `authenticated`	Function permissions	T-SEC-17a (service role can run) / T-SEC-17b (authenticated user cannot)

Always-on security checks (tested in the hardening phase):

- [ ] Every table has permission rules switched on (RLS enabled). There is a test that fails if any public table has none (T-DB-2).
- [ ] Input is checked in the app and again on the server or database (token format, password rule, content lengths, score range).
- [ ] Rate limits from the PRD are enforced on the server: BR3 (5 posts per hour and 5 replies per hour) and BR1 (one check-in per 8 hours).
- [ ] File uploads: not applicable in v1 (no uploads exist).
- [ ] No passwords, tokens or personal data are written to logs (including Edge Function logs and test output).
- [ ] A secret scan of the repository, its history and the built `dist` folder finds no keys.

10. Backend operations

Exact messages come from the PRD (v1.1). The app keeps every message in `src/lib/messages.ts`.

ID	Operation	Who can call it	Input	Output	Rules	Errors (exact message)	Built as	Tests
OP1	Sign up	Logged out	email, password, role (Nurse, Doctor or EMS), token, consent ticked	Account created, verification email sent, handle assigned; response never contains the hash	BR2, token format (Section 18, question 5), password rule, SEC3	"Invalid professional token format. Use SANC/HPCSA number." / "This registration token is already active." / "Password must be at least 8 characters and include 1 number." / "Service connection failed. Tap to retry." (an email that already exists gets the normal success message	Edge Function `signup` (hashes the token with SHA-256 on the server, creates the auth user, inserts the profile, retries the handle up to 10 times)	T-US1-1, T-US1-2, T-BR2-1 to T-BR2-4, T-EDGE-2, T-AUTH-1, T-AUTH-7

						)		
OP 2	Log in	Logged out	email, password	Session	Session limit 14 days, rate limit	"Invalid email or password." / "Too many failed attempts. Try again in 15 mins" / "Please verify your email before logging in."	Supabase Auth `signInWithPassword`	T-US2-1, T-US2-2, T-AUTH-2, T-AUTH-3, T-AUTH-4
OP 3	Request password reset	Anyone	email	Always the same success message; link valid 1 hour	No account enumeration	"If account exists, reset link sent"	Supabase Auth `resetPasswordForEmail` (reset link lifetime set to 3,600 seconds in `config.toml`)	T-US2-3, T-AUTH-5, T-AUTH-6
OP 4	Set new password	User with a recovery link session	new password	Password changed, then S3	Password rule	"Password must be at least 8 characters and include 1 number." / "Password updated."	Supabase Auth `updateUser`	T-US2-4, T-S4-1
OP 5	Log out	Logged in	none	Session cleared, go to		none	Supabase Auth `signOut`	T-S11-2

				S1				
OP 6	Delete account	Logged in (own account)	none (user from the token)	Check-ins and notifications deleted; posts and replies reassigned to Ghost-User; profile and auth user removed; then S1	BR5, SEC16, SEC17	"Service connection failed. Tap to retry."	Edge Function `delete-account` calling `purge_user_data` then the Auth admin delete	T-US1-3, T-BR5-1 to T-BR5-3, T-SEC-16a, T-SEC-16b
OP 7	Submit check-in	Logged in	stress_score, shift_type, note	New row; S5 then S6 with the toast; score 5 also opens M2	BR1, BR4, SEC4, SEC5. The 18:00 SAST reminder banner on S6 shows when the user has no check-in dated today (SAST) and the reminder is enabled	"You logged a check-in recently. Next check-in available in N hours." (N = hours left, rounded up; "1 hour" when N is 1) / "Check-in logged successfully." / "Service connecti	Table insert with trigger `trg_check_ins_interval`	T-US3-1 to T-US3-3, T-US4-1, T-BR1-1 to T-BR1-4, T-BR4-1

						on failed. Tap to retry."		
OP 8	Read my check-ins	Logged in	none	Latest check-in time; last 7 days of scores; dates for the streak	SEC4	"Service connection failed. Tap to retry."	Table select	T-US3-2, T-US7-1, T-US7-2
OP 9	Sync queued check-in	Logged in	the saved offline check-in	Row saved when the connection returns	BR1	"You are offline. Changes will sync when reconnected."	Same insert as OP7, run by `offlineQueue.ts`	T-EDGE-1
OP 10	List circles with stats	Logged in	none	Four circles: name, active members, last post time	SEC7	"Service connection failed. Tap to retry."	View `circle_stats`	T-S7-1, T-DB-12
OP 11	List posts in a circle	Logged in	circle	Latest 50 posts, newest first, with handle, time, text and reply count	SEC7	"Service connection failed. Tap to retry."	Table select with reply count	T-S8-1, T-US5-1
OP 12	Create post	Logged in	circle, content	New post with the author's	BR3, SEC8	"You have reached the limit	Table insert with triggers	T-US5-1, T-

				handle		of 5 posts per hour. Try again later." / "Post exceeds 1000 characters" / "Session expired. Please log in again."		US5-2, T-BR3-1 to T-BR3-4, T-EDGE-4
OP 13	Get post with replies	Logged in	post id	Post and its replies, oldest reply first	SEC7, SEC10	"This debrief is no longer available."	Table select	T-US8-1, T-EDGE-3
OP 14	Create reply	Logged in	post id, content	New reply with the author's handle; the post owner gets an alert	BR3, SEC11	"You have reached the limit of 5 replies per hour. Try again later."	Table insert with triggers	T-US8-1, T-US8-2, T-BR3-5, T-DB-13
OP 15	List and mark alerts	Logged in	none / alert id	Unread reply alerts with the text "A colleague replied to your	SEC13	"Service connection failed. Tap to retry."	Table select and update	T-US8-3

				debrief in" + circle + "Circle." ; marks one read				
OP 16	Read my profile	Logged in	none	handle, role, preferences; the token status shows "Verified" for every signed-in user	SEC1	"Service connection failed. Tap to retry."	Table select (non-secret columns)	T-S11-1
OP 17	Update notification preferences	Logged in	reminder_enabled, reply_alerts_enabled	Preferences saved	SEC2	"Service connection failed. Tap to retry."	Table update	T-S11-3, T-SEC-2a, T-SEC-2b
OP 18	Recent circle activity	Logged in	none	The 2 newest posts across all circles for the S6 cards	SEC7	"Service connection failed. Tap to retry."	Table select, limit 2	T-S6-5

11. Navigation rules

- **Logged out:** can only open S1 (`/`), S2 (`/signup`), S3 (`/login`), S4 (`/forgot-password`) and `/reset-password` (needs a recovery link). Any other route → S1.
- **Logged in, setup not finished:** not applicable in v1 (there is no setup step).
- **Logged in:** opening S1, S2, S3 or S4 → S6. Opening an unknown route → S6.
- **Session:** a session older than 14 days is signed out on app start and the user is sent to S1 (T-AUTH-3).
- **Tabs:** Home (S6), Circles (S7), Resources (S10), Profile (S11). The tab bar is shown on S6, S7, S8, S10 and S11. S8 keeps Circles active. Tapping the active tab scrolls to the top.
- **SOS:** the red SOS icon in the header of every logged-in screen opens M2 over the current screen. Closing M2 returns to the same screen.
- **Back button:** modals M1 and M2 close first. From S6 the back button does not return to S3 or S1 (the app exits). From S8 it goes to S7; from S9 and S12 it goes to the previous screen.
- **After actions:** sign up → S3; log in → S6; submit check-in → S6 (score 5: M2 first, then S6 when dismissed); publish post → S8; delete account or log out → S1; set new password → S3.
- **Navigation map** (from PRD 7.2, with S12 added):

```
flowchart TD
  S1("S1 Welcome") -->|Get Started| S2("S2 Sign Up")
  S1 -->|Log In| S3("S3 Log In")
  S2 -->|Registration complete| S3
  S3 -->|Valid credentials| S6("S6 Home Dashboard")
  S3 -->|Forgot Password?| S4("S4 Forgot Password")
  S4 -->|Back| S3
  S6 --> S5("S5 Check-In")
  S5 -->|Submit Log| S6
  S5 -->|Score 5| M2("M2 SOS Drawer")
  M2 -->|Dismiss| S6
  S6 --> S7("S7 Peer Circles")
  S6 --> S10("S10 Resources")
  S6 --> S11("S11 Profile")
  S6 -->|Activity card or alert| S12("S12 Post Detail")
  S7 --> S8("S8 Circle Feed")
  S8 -->|Plus button| S9("S9 New Post")
  S9 -->|Publish| S8
  S8 --> S12
  S12 --> S8
  S10 -->|Tap to Open SOS Drawer| M2
  S11 -->|Delete Account| M1("M1 Delete Account")
  M1 -->|Confirm| S1
  S11 -->|Log Out| S1
```

12. Testing strategy

12.1 The TDD cycle (every task, every phase)

1. **Red:** write one test for the behaviour, using the acceptance criterion or rule. Run it. It must **fail**, and fail for the expected reason (e.g. "screen not found", not "syntax error").

2. **Green:** write the **smallest** amount of code that makes that test pass. Run **all** tests.

3. **Refactor:** clean up names, remove duplication, move code to the right folder. Run all tests again. They must still pass.

4. Repeat for the next test.

12.2 Test levels

Every level has at least one passing example test at the end of Phase 1 (T-SETUP-1 to T-SETUP-5).

Level	What it proves	Tool	Folder	Command
Unit	Business rules and helper functions give the right answers	Vitest	`tests/unit/`	`npm run test:unit`
Component	Each component and screen shows the right things in every state, with fake data	Vitest + React Testing Library	`tests/component/`	`npm run test:unit`
Database and permissions	Constraints, triggers and permission rules allow and deny the right people	pgTAP	`supabase/tests/database/`	`npm run test:db`
Integration	Each backend operation works against the real local backend,	Vitest + supabase-js	`tests/integration/`	`npm run test:integration`

	including the Edge Functions			
End-to-end	Whole user flows work in a real browser at 360px	Playwright	`tests/e2e/`	`npm run test:e2e`
Manual	Screens match the designs; real-device checks	Human	Checklists in each phase	none

12.3 Test IDs

Every automated test name starts with its ID, so a single test can be found and run on its own.

Prefix	Comes from	Example
T-SETUP-#	Phase 1 tool and setup checks	T-SETUP-1
T-US#-#	PRD acceptance criteria (Section 6)	T-US1-2
T-AUTH-#	Account rules (PRD Section 5)	T-AUTH-1
T-BR#-#	Business rules (PRD 4.4)	T-BR1-1
T-SEC-#a / b	Permission rules (Section 9), allow / deny	T-SEC-3b
T-DB-#	Database constraints and triggers not covered by a BR	T-DB-2
T-INT-#	Backend operations not covered by a T-US test (Section 10)	T-INT-1
T-C-#	Shared components (Section 7.2)	T-C-4
T-S#-# / T-M#-#	Extra states or behaviour of one screen or modal	T-S6-1
T-NAV-#	Navigation rules (Section 11)	T-NAV-1
T-EDGE-#	Edge cases (PRD 6.2)	T-EDGE-2
T-E2E-#	User flows (PRD 7.1)	T-E2E-1

T-NFR-#	Quality requirements (PRD 12.1)	T-NFR-3
T-REL-#	Release checks (release phase)	T-REL-1

The same ID may be used at two levels when both prove the same criterion, e.g. T-US1-1 as a component test and as an integration test.

12.4 Test data rules

- Tests never depend on each other or on the order they run in.
- Database tests start from a fresh reset (migrations + seed).
- Component tests use fake data from the PRD sample data set (8.4), never real network calls.
- Tests never use real personal data or real passwords. Test passwords come from `TEST_USER_PASSWORD`.
- Integration tests create their own users and check-ins, and clean them up.

12.5 Coverage rules

- 100% of PRD acceptance criteria (T-US…) have an automated test, or a manual check where automation is not possible (marked "manual").
- 100% of business rules have unit or database tests.
- 100% of permission rules have an allow test and a deny test.
- 100% of PRD edge cases have a test.
- At least 80% line coverage for business-rule code (`src/lib/rules/`).

13. Phases

13.0 Phase overview

Phase	Name	Features	Screens	Main tests
1	Foundation	none	S1	T-SETUP-1 to T-SETUP-6, T-C-1 to T-C-9, T-S1-1, T-S1-2, T-NFR-1
2	Data and security	none	none	T-DB-1 to T-DB-17, T-SEC-1a to T-SEC-17b, T-BR1-2 to T-BR1-4, T-BR2-3, T-

				BR3-2, T-BR3-3, T-BR3-5, T-BR5 (database level)
3	Accounts	F1	S2, S3, S4, S11, M1	T-US1-1 to T-US1-3, T-US2-1 to T-US2-4, T-BR2-1 to T-BR2-4, T-BR5-1 to T-BR5-3, T-AUTH-1 to T-AUTH-8, T-EDGE-2, T-NAV-1 to T-NAV-4
4	Check-in and SOS	F2, F4	S5, S6 (shell), S10, M2	T-US3-1 to T-US3-3, T-US4-1, T-US6-1, T-BR1-1, T-BR4-1, T-E2E-1, T-E2E-3
5	Peer Circles	F3	S7, S8, S9, S12, S6 (activity and alerts)	T-US5-1, T-US5-2, T-US8-1 to T-US8-3, T-BR3-1, T-BR3-4, T-EDGE-3, T-E2E-2
6	Personal Wellness Log	F5	S6 (chart, streak, Empty)	T-US7-1, T-US7-2, T-C-13, T-S6-4
7	Hardening	none	All	T-EDGE-1, T-EDGE-4, T-EDGE-5, T-NFR-2 to T-NFR-8, T-SEC-18 to T-SEC-21, full T-E2E suite
8	Release	none	All	T-REL-1 to T-REL-5, full suite

Phase 1: Foundation

Goal: the human can open the app on a phone and see the Welcome screen built to its design, and every test level runs and passes.

Covers: Features none · Stories none · Screens S1 · Rules none (design tokens and accessibility basics) · Operations none · Permissions none

Starts when: the human says "Start Phase 1" (Section 18 has no Open rows and Section 4.2 prerequisites are installed).

Step 1: Write the failing tests first (Red)

Test ID	Level	File	What it checks
T-SETUP-1	Unit	`tests/unit/setup.test.ts`	Given the tokens file, when imported, then primary is #0B7A6B, accent #E8F5E9, background #F8FAFC, text #1E293B, error #DC2626
T-SETUP-2	Component	`tests/component/setup.test.tsx`	Given the app is rendered at `/`, then the text "CareGrid SA" is on screen
T-SETUP-3	Database	`supabase/tests/database/000_setup.test.sql`	Given a fresh database, when pgTAP runs, then a trivial test passes
T-SETUP-4	Integration	`tests/integration/setup.test.ts`	Given the local backend is running, when the Supabase client asks for the session, then it connects

			without error
T-SETUP-5	E2E	`tests/e2e/setup.spec.ts`	Given a 360px browser, when the app opens, then S1 shows the "Get Started" button
T-SETUP-6	Unit	`tests/unit/secretScan.test.ts`	Given a sample text containing a key-like string, when the scanner runs, then it reports it; given clean text, it reports nothing
T-NFR-1	Unit	`tests/unit/contrast.test.ts`	Given the tokens, when contrast is calculated, then primary on white, white on primary, text on background and error on white are each at least 4.5:1
T-C-1	Component	`tests/component/Button.test.tsx`	Given a Button, then it shows primary, secondary and danger variants, is at least 44px high, shows a spinner and ignores taps when loading, and ignores taps when disabled
T-C-2	Component	`tests/component/TextField.test.tsx`	Given a

			TextField, then it shows its label and placeholder, shows an error message under the field in error state, and the password type can be shown and hidden
T-C-3	Component	`tests/component/TextArea.test.tsx`	Given a TextArea with a limit, when text goes over the limit, then the counter turns red and the over-limit flag is reported
T-C-4	Component	`tests/component/SelectField.test.tsx`	Given a SelectField with options, when an option is chosen, then the value is reported
T-C-5	Component	`tests/component/Banner.test.tsx`	Given a Banner, then info, warning, error and offline variants show their text
T-C-6	Component	`tests/component/Toast.test.tsx`	Given a Toast, when shown, then it appears and disappears after 3 seconds
T-C-7	Component	`tests/component/Header.test.tsx`	Given a Header, then it shows the logo, title and

			optional back arrow; the red SOS icon shows only when logged in and calls the SOS handler when tapped
T-C-8	Component	`tests/component/TabBar.test.tsx`	Given a TabBar, then it shows Home, Circles, Resources and Profile, highlights the active tab, and each item is at least 44x44px
T-C-9	Component	`tests/component/Skeleton.test.tsx`	Given a Skeleton, then it renders placeholder blocks with an accessible loading label
T-S1-1	Component	`tests/component/S1Welcome.test.tsx`	Given S1 in its normal state, then the wordmark, the card "Operational Wellness for SA Healthcare Workers", the three items Check-in, Peer Debrief and 24/7 Crisis Support, and the buttons "Get Started" (to S2) and "Log In" (to S3)

			are shown
T-S1-2	Component	`tests/component/S1Welcome.test.tsx`	Given S1 with the offline flag on, then the banner "Offline mode — emergency crisis lines active" is shown

- [ ] All tests above are written, run, and fail for the expected reason.

Step 2: Backend (Green)

- [ ] `npx supabase init`; set `supabase/config.toml`: email confirmation required, minimum password length 8, password reset link lifetime 3,600 seconds, no external login providers.
- [ ] Create `scripts/scan-secrets.mjs` (looks for service-role keys, JWT-like strings and `.env` files in the working tree, and in history with `--history`) and add `npm run scan:secrets`.
- [ ] Create the empty `supabase/functions/` and `supabase/tests/database/` folders and the pgTAP example test.
- [ ] Add the npm scripts from Section 4.3 (`db:reset` runs `npx supabase db reset` then `node scripts/seed-users.mjs`; the seed script can be an empty stub until Phase 3).

Step 3: Frontend (Green)

- [ ] Create the Vite + React + TypeScript project, install the Section 4.1 tools only, set up Tailwind from `src/theme/tokens.ts`, self-hosted Inter, Lucide.
- [ ] Add `vite-plugin-pwa` with the manifest (name CareGrid SA, theme colour #0B7A6B, background #F8FAFC, display standalone, icons exported from the designs). No offline caching yet (Phase 7).
- [ ] Build `Button`, `TextField`, `TextArea`, `SelectField`, `Banner`, `Toast`, `Header`, `TabBar`, `Skeleton` to the style guide design (Section 7.2).
- [ ] Build S1 Welcome to `docs/designs/S1-welcome.png` with states Normal and Offline (the offline flag is a prop for now), and the router with routes `/`, `/signup`, `/login` pointing to simple placeholder pages.
- [ ] Add `.env.example`, `.gitignore` (includes `.env`), ESLint, and a first README with setup steps.

Step 4: Refactor and full check

- [ ] Code cleaned up; no duplicated logic; names use PRD key terms.
- [ ] Full check passes (lint, type check, secret scan, every automated test from every phase so far).

Step 5: Manual checks (human)

- [ ] `npm run dev` opens S1 in Chrome device mode at 360px and on the real phone (via the computer's Wi-Fi address).

- [ ] S1 matches its design side by side: layout, text, colours, spacing, Inter font, 16px side margins.
- [ ] Every button and icon is easy to tap (44px minimum).
- [ ] The style guide design and the component look match (Button, Toast, Header, Tab Bar).

Definition of Done

- [ ] Every test in Step 1 passes.
- [ ] All earlier tests still pass (none yet).
- [ ] Every screen in this phase shows all its required states (S1: Normal, Offline).
- [ ] Manual checks are ticked by the human.
- [ ] Progress log updated (Section 17), including the exact installed versions.

Commit message: `Phase 1: Foundation`

STOP. Wait for the human to say "Start Phase 2".

Phase 2: Data and security

Goal: the whole database exists with every rule and permission enforced and proven by tests, before any feature uses it.

Covers: Features none (data for F1 to F5) · Stories none · Screens none · Rules BR1 (database part), BR2 (uniqueness and format), BR3 (database part), BR5 (purge function) · Operations none · Permissions SEC1 to SEC17 (database parts)

Starts when: Phase 1 is complete and the human says "Start Phase 2".

Step 1: Write the failing tests first (Red)

All files are in `supabase/tests/database/`. Each test runs inside a transaction that is rolled back. Tests that act as a user set the database role to `authenticated` with that user's id (Peer-Nurse-402 is "Thandiwe", Peer-EMS-089 is "Sipho").

Test ID	Level	File	What it checks
T-DB-1	Database	`010_tables.test.sql`	Given the migrations, then `profiles`, `check_ins`, `posts`, `replies`, `notifications` and the view `circle_stats` exist with the columns, types, defaults and nullability in Section 8.1
T-DB-2	Database	`010_tables.test.sql`	Given every table in the public schema, then Row-Level Security is enabled on all of them (fails if any table has

			none)
T-DB-15	Database	`010_tables.test.sql`	Given the migrations, then the Ghost-User profile exists with id 00000000-0000-0000-0000-000000000000, handle Ghost-User, role Ghost
T-DB-17	Database	`010_tables.test.sql`	Given a fresh reset with seed data, then there are 4 seeded profiles, 3 posts in Nursing and 2 posts in EMS
T-DB-16	Database	`010_tables.test.sql`	Given the migrations, then the app roles have no read permission on `profiles.token_hash` and can update only `reminder_enabled` and `reply_alerts_enabled` on `profiles`
T-DB-3	Database	`020_check_ins.test.sql`	Given a check-in, when stress_score is 0, 6 or not a whole number, then it is rejected; when 1 to 5, it is accepted
T-DB-4	Database	`020_check_ins.test.sql`	Given a check-in, when shift_type is not Day, Night or Overtime, then it is rejected
T-DB-5	Database	`020_check_ins.test.sql`	Given a check-in, when the note is 301 characters, then it is rejected; 300 characters is accepted
T-BR1-2	Database	`020_check_ins.test.sql`	Given a user with a check-in 2 hours ago, when they insert another, then it is rejected with CHECKIN_TOO_SOON

T-BR1-3	Database	`020_check_ins.test.sql`	Given a user whose last check-in was 8 hours and 1 minute ago, when they insert another, then it is accepted
T-BR1-4	Database	`020_check_ins.test.sql`	Given two different users, when each inserts a check-in within the same hour, then both are accepted (the limit is per user)
T-DB-6	Database	`030_profiles.test.sql`	Given a profile, when the handle is not Peer, role, 3 digits (and not Ghost-User), then it is rejected; Peer-Nurse-402 is accepted
T-DB-7	Database	`030_profiles.test.sql`	Given a profile, when token_hash is not 64 lowercase hex characters, or repeats another profile's hash, then it is rejected
T-DB-8	Database	`030_profiles.test.sql`	Given a profile, when role is not Nurse, Doctor, EMS, Admin or Ghost, then it is rejected
T-BR2-3	Database	`030_profiles.test.sql`	Given an existing handle, when another profile uses the same handle, then it is rejected
T-DB-9	Database	`040_posts_replies.test.sql`	Given a post, when circle_name is not Nursing, Medical, EMS or General, or the content is under 10 or over 1,000 characters after trimming, then it is rejected

T-DB-10	Database	`040_posts_replies.test.sql`	Given a reply, when the content is under 10 or over 1,000 characters after trimming, then it is rejected
T-DB-11	Database	`040_posts_replies.test.sql`	Given a post with replies and alerts, when the post is deleted, then its replies and alerts are deleted too
T-BR3-2	Database	`040_posts_replies.test.sql`	Given a post of exactly 10 and of exactly 1,000 characters, then both are accepted
T-BR3-3	Database	`040_posts_replies.test.sql`	Given a user with 5 posts in the last hour, when they insert a 6th, then it is rejected with POST_RATE_LIMIT; when the earliest post is older than an hour, a new one is accepted
T-BR3-5	Database	`040_posts_replies.test.sql`	Given a user with 5 replies in the last hour, when they insert a 6th, then it is rejected with REPLY_RATE_LIMIT
T-DB-14	Database	`040_posts_replies.test.sql`	Given the migrations, then every index in Section 8.4 exists
T-DB-12	Database	`050_notifications_view.test.sql`	Given seed posts, when `circle_stats` is read, then it returns 4 circles, the right member counts and last post times, and a circle with no posts shows zero members
T-DB-13	Database	`050_notifications_view.test.sql`	Given Sipho replies to Thandiwe's post, then Thandiwe gets one

			alert; when Thandiwe replies to her own post, then no alert; when Thandiwe has reply alerts off, then no alert
T-SEC-1a / T-SEC-1b	Database	`060_security.test.sql`	Thandiwe can read her own profile row; Thandiwe cannot read Sipho's profile row, and no user can read the token_hash column
T-SEC-2a / T-SEC-2b	Database	`060_security.test.sql`	Thandiwe can change her reminder_enabled and reply_alerts_enabled; she cannot change her role, handle or token_hash (for example role to Admin)
T-SEC-3a / T-SEC-3b	Database	`060_security.test.sql`	The service role can insert and delete a profile; a signed-in user cannot insert or delete a profile
T-SEC-4a / T-SEC-4b	Database	`060_security.test.sql`	Thandiwe can read her own check-ins; she cannot read Sipho's check-ins
T-SEC-5a / T-SEC-5b	Database	`060_security.test.sql`	Thandiwe can insert a check-in for herself; she cannot insert a check-in with Sipho's user_id
T-SEC-6a / T-SEC-6b	Database	`060_security.test.sql`	The purge function removes a user's check-ins; a signed-in user cannot update or delete a check-in, not even their own
T-SEC-7a / T-SEC-7b	Database	`060_security.test.sql`	A signed-in user can read posts; someone not signed in (anon)

			cannot
T-SEC-8a / T-SEC-8b	Database	`060_security.test.sql`	Thandiwe can create a post as herself; she cannot create a post with Sipho's author_id
T-SEC-9a / T-SEC-9b	Database	`060_security.test.sql`	Thandiwe can delete her own post; Sipho cannot delete Thandiwe's post
T-SEC-10a / T-SEC-10b	Database	`060_security.test.sql`	A signed-in user can read replies; anon cannot
T-SEC-11a / T-SEC-11b	Database	`060_security.test.sql`	A user can create a reply as themselves; they cannot reply as another user
T-SEC-12a / T-SEC-12b	Database	`060_security.test.sql`	A user can delete their own reply; another user cannot
T-SEC-13a / T-SEC-13b	Database	`060_security.test.sql`	Thandiwe can read and mark read her own alerts; she cannot read or change Sipho's alerts
T-SEC-14a / T-SEC-14b	Database	`060_security.test.sql`	The reply trigger creates an alert; a signed-in user cannot insert an alert directly
T-SEC-15a / T-SEC-15b	Database	`060_security.test.sql`	The test Admin clinician can read their own check-ins; they cannot read another user's check-ins or any token_hash
T-SEC-17a / T-SEC-17b	Database	`060_security.test.sql`	The service role can run `purge_user_data`; a signed-in user and anon cannot
T-BR5-1	Database	`070_purge.test.sql`	Given a user with 3 check-ins, when `purge_user_data`

			runs, then all 3 are deleted
T-BR5-2	Database	`070_purge.test.sql`	Given a user with posts and replies, when `purge_user_data` runs, then every post and reply author_id is the Ghost-User id and author_handle is Ghost-User, and the content is unchanged
T-BR5-3	Database	`070_purge.test.sql`	Given a user, when `purge_user_data` runs, then the profile row is gone and the Ghost-User row remains

- [ ] All tests above are written, run, and fail for the expected reason.

Step 2: Backend (Green)

- [ ] Write the 7 migrations in Section 8.6, in order, matching Section 8.1 exactly (types, defaults, constraints, trigger names, error codes CHECKIN_TOO_SOON, POST_RATE_LIMIT, REPLY_RATE_LIMIT).
- [ ] Column permissions on `profiles`: no app role can read `token_hash`; `authenticated` can update only `reminder_enabled` and `reply_alerts_enabled`.
- [ ] Create every policy in Section 9 (names as listed) and enable RLS on every table.
- [ ] Write `supabase/seed.sql` (Section 8.7) with the fixed user ids used by Phase 3.
- [ ] `npm run db:reset` works from scratch, twice in a row.

Step 3: Frontend (Green)

- [ ] None. This phase has no screens.

Step 4: Refactor and full check

- [ ] Code cleaned up; no duplicated SQL; migration names and comments are clear.
- [ ] Full check passes (lint, type check, secret scan, every automated test from every phase so far).

Step 5: Manual checks (human)

- [ ] In the local Supabase Studio (the address printed by `npx supabase start`), all five tables show Row-Level Security on, and `circle_stats` returns four rows.
- [ ] The Table Editor shows the seeded profiles and posts, and the `profiles` table has no plain-text token anywhere.
- [ ] `npm run db:reset` runs cleanly twice.

Definition of Done

- [ ] Every test in Step 1 passes.
- [ ] All earlier tests still pass.
- [ ] Every screen in this phase shows all its required states (no screens in this phase).
- [ ] Manual checks are ticked by the human.
- [ ] Progress log updated (Section 17).

Commit message: `Phase 2: Data and security`

STOP. Wait for the human to say "Start Phase 3".

Phase 3: Accounts (F1)

Goal: a clinician can sign up with a professional token, verify their email, log in, reset their password, log out and delete their account.

Covers: Features F1 · Stories US1, US2 · Screens S2, S3, S4, S11, M1 (and S6 as an empty placeholder route) · Rules BR2, BR5 · Operations OP1 to OP6, OP16, OP17 · Permissions SEC3, SEC16, SEC17

Starts when: Phase 2 is complete, the updated S2 and S4 designs are exported to `docs/designs/`, the human has given the privacy page text, and the human says "Start Phase 3".

Step 1: Write the failing tests first (Red)

Test ID	Level	File	What it checks
T-BR2-1	Unit	`tests/unit/handle.test.ts`	Given a role and 3 digits, then the handle is Peer, role, digits (Peer-Nurse-402); anything else is invalid; Ghost-User is only valid as the system handle
T-AUTH-1	Unit	`tests/unit/password.test.ts`	Given passwords, then fewer than 8 characters or with no number are invalid; "Password123" is valid
T-BR2-5	Unit	`tests/unit/token.test.ts`	Given tokens, then 6 to 12

			letters or digits with no spaces or symbols is valid; anything else is invalid (Section 18, question 5)
T-AUTH-3	Unit	`tests/unit/session.test.ts`	Given a session that started 15 days ago, when the app starts, then the user is signed out; 13 days ago stays signed in
T-AUTH-4	Unit	`tests/unit/session.test.ts`	Given the sign-in rate-limit error from Supabase, then the message "Too many failed attempts. Try again in 15 mins" is chosen
T-US1-1	Component	`tests/component/S2SignUp.test.tsx`	Given S2, when I enter valid details, a role, a valid token, tick the agreement and tap "Sign Up", then I go to S3 with the message "Check your email to verify your account."
T-US1-2	Component	`tests/component/S2SignUp.test.tsx`	Given an invalid token format, when I tap "Sign Up", then I see "Invalid professional

			token format. Use SANC/HPCSA number." under the field and the field is red
T-S2-1	Component	`tests/component/S2SignUp.test.tsx`	Given a valid form, when the request is in progress, then the button shows "Verifying token..." with a spinner and cannot be tapped again
T-S2-2	Component	`tests/component/S2SignUp.test.tsx`	Given a password under 8 characters or without a number, then "Password must be at least 8 characters and include 1 number." shows; the "Sign Up" button is disabled until the POPIA box is ticked and a role is chosen
T-US2-1	Component	`tests/component/S3LogIn.test.tsx`	Given a verified account, when I enter email and password and tap "Log In", then I am taken to S6
T-US2-2	Component	`tests/component/S3LogIn.test.tsx`	Given a wrong password, when I tap "Log In",

			then I see "Invalid email or password." under the inputs
T-S3-1	Component	`tests/component/S3LogIn.test.tsx`	Given too many failed attempts, then the banner "Too many failed attempts. Try again in 15 mins" shows; and an unverified email shows "Please verify your email before logging in."
T-US2-3	Component	`tests/component/S4ForgotPassword.test.tsx`	Given S4, when I enter an email and tap "Send Reset Link", then the toast "If account exists, reset link sent" shows, for known and unknown emails alike
T-US2-4	Component	`tests/component/S4ForgotPassword.test.tsx`	Given I open the reset link (set new password mode), when I enter a valid new password and tap "Update Password", then I see "Password updated." and go to S3
T-S4-1	Component	`tests/component/S4ForgotPassword.test.tsx`	Given set new password mode, when the

			password breaks the rule, then the password rule message shows and nothing is saved
T-S11-1	Component	`tests/component/S11Profile.test.tsx`	Given S11, then the handle (Peer-Nurse-402), "Verified" token status, Change Password, Notification Preferences, "Log Out" and "Delete Account" show, with the tab bar (Profile active)
T-S11-2	Component	`tests/component/S11Profile.test.tsx`	Given S11, when I tap "Log Out", then I go to S1
T-S11-3	Component	`tests/component/S11Profile.test.tsx`	Given S11, when I switch the daily reminder or reply alerts off, then the preference is saved
T-S11-4	Component	`tests/component/S11Profile.test.tsx`	Given S11, when I tap Change Password, then a reset link is requested and the toast "If account exists, reset link sent"

			shows
T-M1-1	Component	`tests/component/DeleteAccountModal.test.tsx`	Given S11, when I tap "Delete Account", then M1 shows "Delete Account Permanently?", the text "This action cannot be undone. All personal check-in logs will be purged.", "Confirm Deletion" and "Cancel"; "Cancel" closes it
T-M1-2	Component	`tests/component/DeleteAccountModal.test.tsx`	Given M1, when I tap "Confirm Deletion", then the buttons show the processing state until the result arrives
T-US1-3	Component	`tests/component/DeleteAccountModal.test.tsx`	Given M1, when deletion succeeds, then I am taken to S1
T-NAV-1	Component	`tests/component/routes.test.tsx`	Given I am logged out, when I open any route except S1, S2, S3, S4 or the reset link, then I am sent to S1
T-NAV-2	Component	`tests/component/routes.test.tsx`	Given I am logged in, when I open S1, S2,

			S3 or S4, then I am sent to S6
T-NAV-3	Component	`tests/component/routes.test.tsx`	Given S11, then the tab bar shows with Profile active; given S2, S3, S4, then no tab bar
T-NAV-4	Component	`tests/component/routes.test.tsx`	Given I am logged in, when I open an unknown route, then I am sent to S6
T-US1-1	Integration	`tests/integration/signup.test.ts`	Given a new email, a valid token, a role and a password, when `signup` is called, then an auth user and a profile exist, the handle matches the role, and the response has no hash
T-BR2-2	Integration	`tests/integration/signup.test.ts`	Given a signup with token "ABC123456", then the stored token_hash is the 64-character SHA-256 of it and the plain token is found nowhere in the database or the response
T-BR2-4	Integration	`tests/integration/signup.test.ts`	Given the first random handle is already taken,

			when `signup` runs, then it retries and succeeds with a different handle
T-US1-2	Integration	`tests/integration/signup.test.ts`	Given an invalid token format sent straight to the function, then it is refused with "Invalid professional token format. Use SANC/HPCSA number."
T-EDGE-2	Integration	`tests/integration/signup.test.ts`	Given a token already used by another account, when `signup` is called, then it is refused with "This registration token is already active." and no second account is created
T-AUTH-1	Integration	`tests/integration/signup.test.ts`	Given a password under 8 characters or without a number, when `signup` is called, then it is refused with the password message
T-AUTH-7	Integration	`tests/integration/signup.test.ts`	Given an email that already has an account, when `signup` is called with a

			new token, then the response is the same success as for a new email and no profile is added
T-AUTH-2	Integration	`tests/integration/auth.test.ts`	Given an account whose email is not verified, when it logs in, then it is refused; after verification it logs in
T-AUTH-5	Integration	`tests/integration/auth.test.ts`	Given an unknown email, when a reset is requested, then the response is the same as for a known email
T-AUTH-6	Integration	`tests/integration/auth.test.ts`	Given the local Auth settings, then the reset link lifetime is 3,600 seconds and the minimum password length is 8
T-AUTH-8	Integration	`tests/integration/auth.test.ts`	Given a signed-in user, when they set a new password with the rule met, then they can log in with it and not with the old one
T-US1-3	Integration	`tests/integration/deleteAccount.test.ts`	Given a signed-in user, when

			`delete-account` is called, then the auth user and profile no longer exist
T-BR5-1	Integration	`tests/integration/deleteAccount.test.ts`	Given a user with check-ins, when the account is deleted, then no check-ins remain for that user
T-BR5-2	Integration	`tests/integration/deleteAccount.test.ts`	Given a user with posts and replies, when the account is deleted, then those rows remain with Ghost-User as author
T-BR5-3	Integration	`tests/integration/deleteAccount.test.ts`	Given a deleted account, when its old email and password are used to log in, then login fails with "Invalid email or password."
T-SEC-16a / T-SEC-16b	Integration	`tests/integration/deleteAccount.test.ts`	A user with a valid token can delete their own account only; a call with no token is refused, and sending another user's id in the body does not delete that user

T-INT-1	Integration	`tests/integration/profile.test.ts`	Given a signed-in user, when profile and preferences are read and updated through OP16 and OP17, then only the allowed fields change

- [ ] All tests above are written, run, and fail for the expected reason.

Step 2: Backend (Green)

- [ ] `supabase/functions/signup`: validate email, password (Section 18, question 4), role and token format; reject duplicate token; hash the token with SHA-256; create the auth user so the verification email is sent; insert the profile with the random handle (up to 10 retries); return the success message only. Never log the token, hash or password.
- [ ] `supabase/functions/delete-account`: read the user from the verified token only; call `purge_user_data`; delete the auth user with the secret key (read by Supabase at runtime, never from the app).
- [ ] `scripts/seed-users.mjs`: create the four seeded auth users (verified) with the fixed ids and `TEST_USER_PASSWORD`.
- [ ] `npm run functions:serve` works with `.env`.

Step 3: Frontend (Green)

- [ ] `lib/rules/handle.ts`, `token.ts`, `password.ts`; `lib/session.ts` (session provider, 14-day limit); `routes/guards.tsx`; `lib/messages.ts` entries for this phase.
- [ ] S2 Sign Up (fields Email, Password, Role dropdown, Professional Verification Token, POPIA checkbox, "Sign Up") with Normal, Error, Loading.
- [ ] S3 Log In with Normal, Error, Account Locked. S4 with "Send Reset Link" and the Set new password mode (Normal, Success, Error).
- [ ] S11 Profile and Settings with the tab bar and M1 Delete Account modal (Normal, Processing). Header shows the SOS icon on logged-in screens (it opens M2 from Phase 4).
- [ ] S6, S7 and S10 routes exist as plain placeholder pages with the tab bar so navigation works. They are replaced in Phases 4 to 6.
- [ ] Link the S2 consent checkbox label to `public/privacy.html`. The human writes the privacy text (Section 18, question 28); the agent only creates the file from it.
- [ ] Build every screen to its design in Section 7.3.

Step 4: Refactor and full check

- [ ] Code cleaned up; no duplicated logic; names use PRD key terms.
- [ ] Full check passes (lint, type check, secret scan, every automated test from every phase so far).

Step 5: Manual checks (human)

- [ ] On the real phone: sign up with a new email and a valid token, open the verification link from the local email inbox (the address printed by `npx supabase start`), then log in and land on the S6 placeholder.
- [ ] Try a wrong password repeatedly and confirm the locked message appears.
- [ ] Request a password reset, open the link, set a new password, log in again.
- [ ] Delete the account from S11 and confirm you are back on S1 and cannot log in.
- [ ] Each screen in this phase matches its design side by side: layout, text, colours, spacing.

Definition of Done

- [ ] Every test in Step 1 passes.
- [ ] All earlier tests still pass.
- [ ] Every screen in this phase shows all its required states.
- [ ] Manual checks are ticked by the human.
- [ ] Progress log updated (Section 17).

Commit message: `Phase 3: Accounts`

STOP. Wait for the human to say "Start Phase 4".

Phase 4: Check-in and SOS (F2, F4)

Goal: a clinician can log shift stress in under 30 seconds, is shown the SOS drawer when they log a 5, and can call a crisis helpline with one tap from any screen.

Covers: Features F2, F4 · Stories US3, US4, US6 · Screens S5, S6 (shell), S10, M2 · Rules BR1, BR4 · Operations OP7, OP8 · Permissions SEC4, SEC5

Starts when: Phase 3 is complete and the human says "Start Phase 4".

Step 1: Write the failing tests first (Red)

Test ID	Level	File	What it checks
T-BR1-1	Unit	`tests/unit/checkIn.test.ts`	Given a last check-in time, then `canCheckIn` is false within 8 hours and true after; `hoursRemaining` is rounded up (2 hours ago gives 6); scores 0, 6 and 3.5 are invalid, 1 to 5 valid
T-BR4-1	Unit	`tests/unit/sos.test.ts`	Given scores, then `shouldShowSos` is true only for 5
T-US3-3	Unit	`tests/unit/checkIn.test.ts`	Given the time in SAST, then the reminder shows only at or after 18:00

			SAST when no check-in exists for today
T-C-10	Component	`tests/component/RatingSelector.test.tsx`	Given the rating selector, then buttons 1 to 5 show (1 = Calm, 5 = Extreme Stress), one can be selected, each at least 44x44px
T-C-11	Component	`tests/component/ResourceCard.test.tsx`	Given a resource with a number, then a call button has the correct `tel:` link; a resource without a number has no call button
T-US3-1	Component	`tests/component/S5CheckIn.test.tsx`	Given S5, when I select 4, choose "Night Shift", type a note and tap "Submit Log", then the log is saved and I go to S6 with the toast "Check-in logged successfully."
T-US3-2	Component	`tests/component/S5CheckIn.test.tsx`	Given a check-in 2 hours ago, when I open S5, then I see "You logged a check-in recently. Next check-in available in 6 hours." and the submit button is disabled
T-US4-1	Component	`tests/component/S5CheckIn.test.tsx`	Given S5, when I select 5 and tap "Submit Log", then the log is saved and M2 slides up with "We care about your safety. Tap to call SADAG instantly."; dismissing M2 goes to S6
T-S5-1	Component	`tests/component/S5CheckIn.test.tsx`	Given S5, then the shift dropdown offers Day

			Shift, Night Shift and Overtime, the note counter stops at 300, and "Submit Log" is disabled until a score is chosen
T-S5-2	Component	`tests/component/S5CheckIn.test.tsx`	Given the server refuses with CHECKIN_TOO_SOON, then the restricted banner shows and nothing else changes
T-M2-1	Component	`tests/component/SosDrawer.test.tsx`	Given M2, then it shows "Need Immediate Help?", the SADAG card "SADAG 24/7 Helpline (0800 567 567)" and the second card with its number, and "Dismiss" closes it
T-M2-2	Component	`tests/component/SosDrawer.test.tsx`	Given M2, then the first card links to `tel:0800567567` and the second to `tel:0800212223`
T-M2-3	Component	`tests/component/SosDrawer.test.tsx`	Given M2 opened from a score of 5, then the alert line is shown; opened from the header, the alert line is not shown
T-US6-1	Component	`tests/component/Header.test.tsx`	Given any logged-in screen (S5, S6, S10, S11), when I tap the red SOS icon, then M2 opens with the tel: links for SADAG and the second helpline
T-S6-1	Component	`tests/component/S6Home.test.tsx`	Given S6, then the header (logo and red SOS), the welcome card

			with my handle, the "Log Today's Shift Stress" button (to S5) and the tab bar (Home active) show
T-S6-2	Component	`tests/component/S6Home.test.tsx`	Given data is loading, then skeleton cards show
T-S6-3	Component	`tests/component/S6Home.test.tsx`	Given it is after 18:00 SAST with no check-in today and reminders on, then the banner "Shift complete? Take 30 seconds to log your stress score." shows and tapping it opens S5; with reminders off, it does not show
T-S10-1	Component	`tests/component/S10Resources.test.tsx`	Given S10, then the header "Support & Crisis Directory", the button "Tap to Open SOS Drawer" and the cards SADAG 24/7 Helpline, EAP Services, Netcare Helpline and Legal Advisory show, with the tab bar (Resources active)
T-S10-2	Component	`tests/component/S10Resources.test.tsx`	Given S10, then the SADAG card links to `tel:0800567567` and the Netcare card to `tel:082911`; EAP Services and Legal Advisory have no call button; "Tap to Open SOS Drawer" opens M2
T-US3-1	Integration	`tests/integration/checkIn.test.ts`	Given a signed-in user, when OP7 runs with score 4, "Night" and a note, then one row is

			saved for that user
T-BR1-2	Integration	`tests/integration/checkIn.test.ts`	Given a check-in 2 hours ago, when OP7 runs again, then it is refused and the app maps the error to the restricted message
T-US4-1	Integration	`tests/integration/checkIn.test.ts`	Given score 5, when OP7 runs, then the row is saved (the drawer is an app behaviour)
T-US3-2	Integration	`tests/integration/checkIn.test.ts`	Given a user with a check-in, when OP8 runs, then it returns the latest check-in time and only that user's rows
T-E2E-1	E2E	`tests/e2e/flow1.spec.ts`	Flow 1: sign up, confirm email, log in, open S5 from S6, select 3, submit, land on S6 with the success toast
T-E2E-3	E2E	`tests/e2e/flow3.spec.ts`	Flow 3: on any screen tap the red SOS button, M2 opens, the "Call SADAG Helpline" card has the link `tel:0800567567`

- [ ] All tests above are written, run, and fail for the expected reason.

Step 2: Backend (Green)

- [ ] No new migrations. Confirm OP7 and OP8 work through the Phase 2 table, policies and trigger.
- [ ] Add the check-in and check-in-history data hooks (`hooks/`) and the error mapping from CHECKIN_TOO_SOON to the restricted message.

Step 3: Frontend (Green)

- [ ] `lib/rules/checkIn.ts`, `lib/rules/sos.ts`, `lib/format.ts` (SAST times), `data/resources.ts` (Section 7.3 resource data).
- [ ] `RatingSelector`, `ResourceCard`, `SosDrawer` (M2).
- [ ] S5 Stress Check-In with Normal, Restricted and High Alert states; S10 Resources and SOS with Normal (Offline in Phase 7).

- [ ] S6 shell: header, welcome card with handle, primary action card, reminder banner, tab bar, Loading skeleton (chart, streak, activity cards and the Empty state come in Phases 5 and 6).
- [ ] Wire the Header SOS icon to M2 on every logged-in screen. Build to the designs in Section 7.3.

Step 4: Refactor and full check

- [ ] Code cleaned up; no duplicated logic; names use PRD key terms.
- [ ] Full check passes (lint, type check, secret scan, every automated test from every phase so far).
- [ ] E2E tests T-E2E-1 and T-E2E-3 pass (`npm run test:e2e`, with the backend and functions running).

Step 5: Manual checks (human)

- [ ] On the real phone, log a check-in in under 30 seconds and see the toast on S6.
- [ ] Try a second check-in straight away and confirm the restricted banner shows the correct hours.
- [ ] Log a 5 (on a test account) and confirm M2 slides up; tap each call card and confirm the phone dialer opens with the right number (cancel before it dials).
- [ ] Tap the red SOS icon on S5, S6, S10 and S11.
- [ ] Each screen in this phase matches its design side by side: layout, text, colours, spacing.

Definition of Done

- [ ] Every test in Step 1 passes.
- [ ] All earlier tests still pass.
- [ ] Every screen in this phase shows all its required states (S6 completes in Phase 6, S10 Offline in Phase 7).
- [ ] Manual checks are ticked by the human.
- [ ] Progress log updated (Section 17).

Commit message: `Phase 4: Check-in and SOS`

STOP. Wait for the human to say "Start Phase 5".

Phase 5: Peer Circles (F3)

Goal: a clinician can read the four Peer Circles, post an anonymous debrief, reply to a debrief, and see an alert when a colleague replies to theirs.

Covers: Features F3 · Stories US5, US8 · Screens S7, S8, S9, S12, S6 (activity cards and reply alerts) · Rules BR3 · Operations OP10 to OP15, OP18 · Permissions SEC7 to SEC14

Starts when: Phase 4 is complete, the S12 design is exported to `docs/designs/`, and the human says "Start Phase 5".

Step 1: Write the failing tests first (Red)

Test ID	Level	File	What it checks
T-BR3-1	Unit	`tests/unit/post.test.ts`	Given texts, then

			fewer than 10 or more than 1,000 characters after trimming are invalid; exactly 10 and exactly 1,000 are valid; spaces-only is invalid
T-C-12	Component	`tests/component/PostCard.test.tsx`	Given a post, then the handle, circle, timestamp (for example 27 Oct 2026), content and reply count show
T-BR3-4	Component	`tests/component/PostCard.test.tsx`	Given content with a web address, then it is shown as plain text and no clickable link exists
T-S7-1	Component	`tests/component/S7PeerCircles.test.tsx`	Given S7, then the header "Peer Debrief Circles", the four cards Nursing Debriefs, Doctors Forum, EMS Emergency Room and General Wellness, each with its active member count and last post time, and the tab bar (Circles active) show; tapping a card goes to S8 for that circle
T-S7-2	Component	`tests/component/S7PeerCircles.test.tsx`	Given data is loading, then skeleton cards show
T-S7-3	Component	`tests/component/S7PeerCircles.test.tsx`	Given no circles come back, then "No active channels" shows

T-S8-1	Component	`tests/component/S8CircleFeed.test.tsx`	Given S8, then the channel name, back button, SOS icon, post cards (handle, timestamp, content, reply count), the "+" button (to S9) and the tab bar show; tapping a card opens S12
T-S8-2	Component	`tests/component/S8CircleFeed.test.tsx`	Given no posts, then "No debriefs yet. Be the first to share." shows
T-S8-3	Component	`tests/component/S8CircleFeed.test.tsx`	Given data is loading, then skeletons show
T-US5-1	Component	`tests/component/S9NewPost.test.tsx`	Given S9 in the Nursing circle, when I enter a 50-character post and tap "Publish Debrief", then I go to S8 and my post is at the top with the handle Peer-Nurse-402
T-US5-2	Component	`tests/component/S9NewPost.test.tsx`	Given a post over 1,000 characters, then the counter turns red, "Post exceeds 1000 characters" shows and "Publish Debrief" is disabled
T-S9-1	Component	`tests/component/S9NewPost.test.tsx`	Given S9, then the header "Publish Anonymous Debrief", "Cancel", the line "Posting in Nursing Circle" and the counter show; under 10 characters the button is disabled;

			while publishing the button shows a spinner
T-S9-2	Component	`tests/component/S9NewPost.test.tsx`	Given the server refuses with POST_RATE_LIMIT, then "You have reached the limit of 5 posts per hour. Try again later." shows and the draft text stays
T-US8-1	Component	`tests/component/S12PostDetail.test.tsx`	Given S12, then the post, its replies (oldest first, each with handle and time), the reply box and the "Send Reply" button show; when I send a valid reply, it appears in the list
T-US8-2	Component	`tests/component/S12PostDetail.test.tsx`	Given a reply under 10 or over 1,000 characters, then "Send Reply" is disabled and the counter turns red over the limit; the REPLY_RATE_LIMIT error shows "You have reached the limit of 5 replies per hour. Try again later."
T-US8-3	Component	`tests/component/S6Home.test.tsx`	Given an unread reply alert, then S6 shows the card "A colleague replied to your debrief in Nursing Circle."; tapping it opens S12 and marks it read; with no alerts or

			alerts turned off, no card shows
T-S6-5	Component	`tests/component/S6Home.test.tsx`	Given S6, then "Recent Peer Circle Activity" shows the 2 newest posts (handle, circle, time, first lines of text); tapping one opens S12
T-S12-1	Component	`tests/component/S12PostDetail.test.tsx`	Given the post is loading, then skeletons show; the screen has the back arrow, SOS icon and no tab bar
T-EDGE-3	Component	`tests/component/S12PostDetail.test.tsx`	Given I am reading a post that its author deletes, when the app loads it again, then "This debrief is no longer available." shows, the card is removed and I return to the feed (S8)
T-INT-2	Integration	`tests/integration/circles.test.ts`	Given seed posts, when OP10 runs, then it returns four circles with correct member counts and last post times
T-INT-3	Integration	`tests/integration/circles.test.ts`	Given a circle with posts and replies, when OP11 runs, then posts come newest first, at most 50, each with its reply count; when OP18 runs, it returns the 2 newest posts overall
T-US5-1	Integration	`tests/integration/posts.test.ts`	Given a signed-in

			nurse, when OP12 runs with a 50-character text, then a post exists with author_handle equal to the user's handle
T-BR3-1	Integration	`tests/integration/posts.test.ts`	Given texts of 9 and 1,001 characters sent straight to the server, then both are refused; 10 and 1,000 are accepted
T-BR3-3	Integration	`tests/integration/posts.test.ts`	Given 5 posts in an hour, when a 6th is sent, then it is refused and the app maps the error to the rate-limit message
T-US8-1	Integration	`tests/integration/replies.test.ts`	Given a post, when another user replies (OP14) and OP13 runs, then the reply appears with that user's handle
T-BR3-5	Integration	`tests/integration/replies.test.ts`	Given 5 replies in an hour, when a 6th is sent, then it is refused and mapped to the reply rate-limit message
T-US8-3	Integration	`tests/integration/replies.test.ts`	Given Sipho replies to Thandiwe's post, when Thandiwe lists alerts (OP15), then she has one unread alert; after marking it read it no longer shows as unread; Sipho cannot read it
T-E2E-2	E2E	`tests/e2e/flow2.spec.ts`	Flow 2: from S6 open Peer Circles, choose

	Nursing Debriefs, tap "+", type a debrief, publish, and see the post at the top of the feed

- [ ] All tests above are written, run, and fail for the expected reason.

Step 2: Backend (Green)

- [ ] No new migrations. Confirm OP10 to OP15 and OP18 work through the Phase 2 tables, view, triggers and policies.
- [ ] Add the data hooks for circles, posts, replies and alerts, and the error mapping for POST_RATE_LIMIT and REPLY_RATE_LIMIT.

Step 3: Frontend (Green)

- [ ] `lib/rules/post.ts`; circle display names and routes (Section 8.1); `PostCard` (links shown as plain text, never clickable).
- [ ] S7, S8, S9 and S12 to their designs, each with the required states in Section 7.3.
- [ ] S6: add the "Recent Peer Circle Activity" cards and the reply alert cards.
- [ ] Keep the S9 draft in memory while publishing so a failed publish keeps the text.

Step 4: Refactor and full check

- [ ] Code cleaned up; no duplicated logic; names use PRD key terms.
- [ ] Full check passes (lint, type check, secret scan, every automated test from every phase so far).
- [ ] E2E tests T-E2E-1 to T-E2E-3 pass.

Step 5: Manual checks (human)

- [ ] With two test accounts on two browsers or phones: post a debrief as Peer-Nurse-402, reply as Peer-EMS-089, and confirm the first user sees the alert on S6.
- [ ] Paste a web address into a post and confirm it cannot be tapped.
- [ ] Post 5 times in an hour and confirm the 6th shows the rate-limit message.
- [ ] Confirm no screen shows an email address or a real name anywhere.
- [ ] Each screen in this phase matches its design side by side: layout, text, colours, spacing.

Definition of Done

- [ ] Every test in Step 1 passes.
- [ ] All earlier tests still pass.
- [ ] Every screen in this phase shows all its required states.
- [ ] Manual checks are ticked by the human.
- [ ] Progress log updated (Section 17).

Commit message: `Phase 5: Peer Circles`

STOP. Wait for the human to say "Start Phase 6".

Phase 6: Personal Wellness Log (F5)

Goal: a clinician can see their 7-day stress chart and daily streak on the Home Dashboard.

Covers: Features F5 · Stories US7 · Screens S6 (chart, streak, Empty state) · Rules none · Operations OP8 · Permissions SEC4

Starts when: Phase 5 is complete and the human says "Start Phase 6".

Step 1: Write the failing tests first (Red)

Test ID	Level	File	What it checks
T-US7-2	Unit	`tests/unit/streak.test.ts`	Given check-in times, then the streak counts consecutive SAST calendar days with at least one check-in, ending today or yesterday; a gap of a full day resets it to 0; no check-ins gives 0
T-US7-3	Unit	`tests/unit/streak.test.ts`	Given check-ins over the last 10 days, then the chart series is the last 7 SAST days, oldest first; a day with several check-ins uses its highest score; a day with none is empty
T-C-13	Component	`tests/component/StressTrendChart.test.tsx`	Given a 7-day series, then 7 bars show on a 1 to 5 scale, empty days have no bar, and each bar has an

			accessible label with day and score
T-US7-1	Component	`tests/component/S6Home.test.tsx`	Given S6 with logged scores, then the Weekly Stress Trend shows my 7-day bar chart reflecting those scores
T-S6-4	Component	`tests/component/S6Home.test.tsx`	Given no check-ins in the last 7 days, then "No check-ins logged this week" shows instead of the chart
T-S6-6	Component	`tests/component/S6Home.test.tsx`	Given a streak of 3, then the welcome card shows the daily streak counter with 3
T-US7-1	Integration	`tests/integration/checkIn.test.ts`	Given check-ins 2, 5 and 9 days ago, when OP8 runs, then the 7-day range includes the first two only and only for that user

- [ ] All tests above are written, run, and fail for the expected reason.

Step 2: Backend (Green)

- [ ] No new migrations. Extend the OP8 hook to fetch the last 7 days and the dates needed for the streak.

Step 3: Frontend (Green)

- [ ] `lib/rules/streak.ts` (streak and 7-day series in SAST).

- [ ] `StressTrendChart` as simple SVG with token colours (no chart library).
- [ ] Complete S6 to its design with all states: Normal, Empty, Loading, Offline (the offline banner is wired in Phase 7).

Step 4: Refactor and full check

- [ ] Code cleaned up; no duplicated logic; names use PRD key terms.
- [ ] Full check passes (lint, type check, secret scan, every automated test from every phase so far).
- [ ] E2E tests T-E2E-1 to T-E2E-3 still pass.

Step 5: Manual checks (human)

- [ ] With the seeded test account, confirm the Empty state, then log a check-in and see the chart and streak update.
- [ ] Check the chart is readable at 360px and the bar labels can be read by a screen reader.
- [ ] S6 matches its design side by side: layout, text, colours, spacing.

Definition of Done

- [ ] Every test in Step 1 passes.
- [ ] All earlier tests still pass.
- [ ] Every screen in this phase shows all its required states.
- [ ] Manual checks are ticked by the human.
- [ ] Progress log updated (Section 17).

Commit message: `Phase 6: Personal Wellness Log`

STOP. Wait for the human to say "Start Phase 7".

Phase 7: Hardening

Goal: the app works offline for crisis numbers and check-ins, handles every error and edge case with the exact messages, and meets the accessibility, speed and security requirements.

Covers: Features none (quality for F1 to F5) · Stories none · Screens All · Rules BR1, BR3 (limits re-checked) · Operations OP9 · Permissions all (always-on checks in Section 9)

Starts when: Phase 6 is complete and the human says "Start Phase 7".

Step 1: Write the failing tests first (Red)

Test ID	Level	File	What it checks
T-EDGE-1	Component	`tests/component/S5CheckIn.test.tsx`	Given the internet drops, when I tap "Submit Log", then "You are offline. Log saved locally." shows, the log is kept in LocalStorage, and I am not allowed to queue a second one within 8 hours
T-	Integration	`tests/integration/offlineQueue.test.ts	Given a queued check-in, when

EDGE-1		`	the connection returns, then it is sent once and removed from the queue; if the server refuses it with CHECKIN_TOO_SOON, then it is dropped and the restricted message shows
T-EDGE-4	Component	`tests/component/S9NewPost.test.tsx`	Given my session expires while I have a draft, when I publish, then "Session expired. Please log in again." shows, the draft stays in LocalStorage, and after I log in again it is back in S9
T-EDGE-5	Component	`tests/component/errorStates.test.tsx`	Given the database is unreachable, then "Service temporarily unavailable. Try again shortly." shows together with the SADAG and second helpline numbers (from `data/resources.ts`); other load errors show "Service connection failed. Tap to retry." and tapping retries
T-S1-3	Component	`tests/component/offline.test.tsx`	Given the browser goes offline, then S1 shows "Offline mode — emergency crisis lines active", S6 shows "You are offline. Changes will sync when reconnected." and S10 shows the same banner as S1 with all numbers still visible
T-NFR-2	Unit	`tests/unit/bundleSize.test.ts`	Given a production build, when `scripts/check-bundle-size.mjs` runs, then every route loads at most 200 KB (compressed)
T-NFR-3	Component	`tests/component/touchTargets.test.tsx`	Given every screen, then each button, link, tab, rating button and input is at least 44x44px
T-NFR-4	Unit	`tests/unit/format.test.ts`	Given dates and phone numbers, then dates read like 27 Oct 2026, times are SAST, phone numbers can be shown in +27 format, and the page language is English

			(South Africa)
T-NFR-5	E2E	`tests/e2e/offline.spec.ts`	Given the app was opened once online, when the browser goes offline and reloads, then the app shell loads, S10 shows every number and the `tel:` links work
T-NFR-7	Unit	`tests/unit/typography.test.ts`	Given the tokens, then body text is at least 16px and caption text is no smaller than 12px
T-SEC-18	Integration	`tests/integration/validation.test.ts`	Given invalid data sent straight to the server (score 6, note of 301 characters, post of 1,001 characters, bad token format), then every request is refused
T-SEC-19	Unit	`tests/unit/noSensitiveLogs.test.ts`	Given `src/` and `supabase/functions/`, then no console or log call includes a password, token, hash or email variable
T-SEC-20	Unit	`tests/unit/secretScan.test.ts`	Given the repository, when the secret scan runs, then it finds no keys
T-SEC-21	Unit	`tests/unit/bundleSecrets.test.ts`	Given the production build in `dist/`, then it contains neither the service role key nor the text SUPABASE_SERVICE_ROLE_KEY
T-E2E-1 to T-E2E-3	E2E	`tests/e2e/`	Given the whole suite, then T-E2E-1, T-E2E-2, T-E2E-3 and T-NFR-5 all pass together

T-EDGE-2 (duplicate token) and T-EDGE-3 (post deleted while reading) were built in Phases 3 and 5 and must still pass. The manual checks below cover T-NFR-6 and T-NFR-8 (marked manual).

- [ ] All tests above are written, run, and fail for the expected reason.

Step 2: Backend (Green)

- [ ] `lib/offlineQueue.ts` sync listener (OP9): one pending check-in at most, sent when the connection returns.

- [ ] Confirm all server-side checks in T-SEC-18 are enforced (database constraints and Edge Function validation).
- [ ] Remove any logging of sensitive values from Edge Functions.

Step 3: Frontend (Green)

- [ ] Service worker (`vite-plugin-pwa`): cache the app shell, built assets, fonts, icons and the crisis data so the app and S10 load offline. Never cache Supabase API responses.
- [ ] Wire the offline banners on S1, S6 and S10 (Section 7.3) and the offline check-in and draft handling.
- [ ] Add friendly error and "service unavailable" states everywhere an operation can fail, with the exact messages from Section 10 and `lib/messages.ts`.
- [ ] Accessibility pass: 44px touch targets, visible focus, labelled inputs and icon buttons, 16px body text, contrast from the tokens.
- [ ] `scripts/check-bundle-size.mjs` and the build checks for T-NFR-2 and T-SEC-21.

Step 4: Refactor and full check

- [ ] Code cleaned up; no duplicated logic; names use PRD key terms.
- [ ] Full check passes (lint, type check, secret scan, every automated test from every phase so far).
- [ ] The full E2E suite passes.

Step 5: Manual checks (human)

- [ ] On the real phone: turn on aeroplane mode and confirm S10 and the SOS drawer still show the numbers and the dialer opens (T-NFR-5).
- [ ] Submit a check-in offline, turn the connection back on, and confirm it syncs.
- [ ] T-NFR-6 (manual): in Chrome DevTools, throttle to Slow 3G and confirm each main screen loads within 2.5 seconds.
- [ ] T-NFR-8 (manual): check text and button contrast with WebAIM on the real screens, and tab through each screen with a keyboard to confirm visible focus.
- [ ] Read every error message on screen and compare with Section 10; none is invented.
- [ ] Each screen still matches its design side by side.

Definition of Done

- [ ] Every test in Step 1 passes.
- [ ] All earlier tests still pass.
- [ ] Every screen in this phase shows all its required states.
- [ ] Manual checks are ticked by the human.
- [ ] Progress log updated (Section 17).

Commit message: `Phase 7: Hardening`

STOP. Wait for the human to say "Start Phase 8".

Phase 8: Release

Goal: the app is deployed, installable on a real phone as a PWA, and the demo runs from start to finish.

Covers: Features none · Stories none · Screens All · Rules none · Operations none · Permissions none (hosted settings re-checked)

Starts when: Phase 7 is complete and the human says "Start Phase 8".

Step 1: Write the failing tests first (Red)

Test ID	Level	File	What it checks
T-REL-1	Integration	`tests/integration/release.test.ts`	Given the repository, then `.env.example` lists every variable in Section 6, `.env` is in `.gitignore`, and the README mentions every command in Section 4.3 and the test accounts
T-REL-2	Unit	`tests/unit/manifest.test.ts`	Given a production build, then the web manifest has the name CareGrid SA, theme colour #0B7A6B, standalone display and icons, and the service worker file exists
T-REL-3	Unit	`tests/unit/secretScan.test.ts`	Given the repository history (`--history`), then the secret scan finds no keys
T-REL-4	Manual	Demo script	Given the deployed URL on a real phone, when the three flows in Section 16 are run, then each finishes without errors
T-REL-5	Manual	Hosted checklist	Given the hosted Supabase project, then Row-Level

	Security is on for every table, email confirmation is on, the password minimum is 8 and the reset link lifetime is 1 hour

- [ ] All automated tests above are written, run, and fail for the expected reason.

Step 2: Backend (Green)

- [ ] The human creates the hosted Supabase project (EU region as in PRD 12.4) and the agent applies the migrations with `npx supabase db push` and deploys both Edge Functions with `npx supabase functions deploy`.
- [ ] Set the hosted Auth settings to match `config.toml` and set the Site URL and redirect URL to the Vercel address.
- [ ] Create the hosted demo accounts by hand through the app (never use `TEST_USER_PASSWORD` on the hosted project), and set one Admin by hand in the Supabase console.

Step 3: Frontend (Green)

- [ ] Connect the repository to Vercel; set only `VITE_SUPABASE_URL` and `VITE_SUPABASE_ANON_KEY` there; deploy.
- [ ] Complete `README.md`: setup, every command, test accounts (local only), how to run each test level, deployment notes.
- [ ] Write the demo script into `README.md` (the three flows in Section 16).

Step 4: Refactor and full check

- [ ] Code cleaned up; no unused files or code; names use PRD key terms.
- [ ] Full check passes on a clean install (fresh clone, install, start backend, reset database, full check) and the full E2E suite passes.

Step 5: Manual checks (human)

- [ ] Open the Vercel URL on the real phone, add it to the home screen, and confirm it opens full screen with the CareGrid SA icon.
- [ ] Run the demo script on the deployed app: sign up, check in, post a debrief, open the SOS drawer.
- [ ] In the hosted Supabase dashboard, confirm RLS is on for every table and no secret key appears in Vercel.
- [ ] The built app on the phone matches the designs, screen by screen.

Definition of Done

- [ ] Every test in Step 1 passes (manual ones ticked by the human).
- [ ] All earlier tests still pass.
- [ ] Every screen shows all its required states.
- [ ] Manual checks are ticked by the human.

- [ ] Progress log updated (Section 17).

Commit message: `Phase 8: Release`

STOP. The plan is complete. Hand the project to the human for the final demo.

14. Traceability matrix

Feature	Stories	Acceptance tests	Rule tests	Screens	Operations	Phase
F1 Authentication and Anonymity	US1, US2	T-US1-1, T-US1-2, T-US1-3, T-US2-1, T-US2-2, T-US2-3, T-US2-4	T-BR2-1 to T-BR2-5, T-BR5-1 to T-BR5-3, T-AUTH-1 to T-AUTH-8, T-EDGE-2, T-SEC-1a to T-SEC-3b, T-SEC-16a, T-SEC-16b, T-SEC-17a, T-SEC-17b	S1, S2, S3, S4, S11, M1	OP1 to OP6, OP16, OP17	3 (S1 built in 1)
F2 Shift-Stress Check-In	US3, US4	T-US3-1, T-US3-2, T-US3-3, T-US4-1	T-BR1-1 to T-BR1-4, T-BR4-1, T-SEC-4a to T-SEC-6b, T-	S5, S6, M2	OP7, OP8, OP9	4 (offline in 7)

			EDGE-1			
F3 Peer Circles	US5, US8	T-US5-1, T-US5-2, T-US8-1, T-US8-2, T-US8-3	T-BR3-1 to T-BR3-5, T-SEC-7a to T-SEC-14b, T-DB-12, T-DB-13, T-EDGE-3, T-EDGE-4	S6 (activity, alerts), S7, S8, S9, S12	OP10 to OP15, OP18	5
F4 Crisis and SOS Directory	US4, US6	T-US4-1, T-US6-1	T-BR4-1, T-M2-1 to T-M2-3, T-S10-1, T-S10-2, T-NFR-5, T-EDGE-5	S10, M2	none (static data in `data/resources.ts`)	4 (offline in 7)
F5 Personal Wellness Log	US7	T-US7-1	T-US7-2, T-US7-3, T-C-13, T-S6-4, T-S6-6	S6	OP8	6
Quality and security (PRD 12)	none	none	T-NFR-1 to T-NFR-8, T-SEC-18 to T-SEC-21, T-DB-1 to T-DB-17, T-E2E-1 to T-E2E-3	All	All	1, 2, 7

15. Acceptance test checklist

Acceptance criteria (PRD Section 6)

- [ ] T-US1-1: sign up with a valid token goes to S3 with "Check your email to verify your account." (automated)
- [ ] T-US1-2: invalid token format shows the error under the field (automated)
- [ ] T-US1-3: confirmed account deletion ends at S1 and removes the account (automated)
- [ ] T-US2-1: valid log in goes to S6 (automated)
- [ ] T-US2-2: wrong password shows "Invalid email or password." (automated)
- [ ] T-US2-3: forgot password shows "If account exists, reset link sent" (automated)
- [ ] T-US2-4: set new password from the email link works (automated)
- [ ] T-US3-1: check-in saved, redirect to S6 with the toast (automated)
- [ ] T-US3-2: second check-in within 8 hours shows the restricted banner and disables submit (automated)
- [ ] T-US3-3: 18:00 SAST reminder banner on S6 (automated)
- [ ] T-US4-1: score 5 opens M2 with the care message (automated)
- [ ] T-US5-1: a 50-character post appears on S8 with the handle (automated)
- [ ] T-US5-2: a post over 1,000 characters disables "Publish Debrief" (automated)
- [ ] T-US6-1: the SOS icon opens M2 with tel: links on any screen (automated)
- [ ] T-US7-1: 7-day stress chart reflects logged scores (automated)
- [ ] T-US8-1: reply to a post appears in the list (automated)
- [ ] T-US8-2: reply length and rate-limit rules (automated)
- [ ] T-US8-3: reply alert card on S6 (automated)

Edge cases (PRD 6.2)

- [ ] T-EDGE-1: internet drops during check-in submit, log saved locally and synced later (automated)
- [ ] T-EDGE-2: duplicate registration token refused (automated)
- [ ] T-EDGE-3: post deleted while being read (automated)
- [ ] T-EDGE-4: session expires during a post draft, draft preserved (automated)
- [ ] T-EDGE-5: database downtime shows the friendly message and the crisis numbers (automated)

Business rules, accounts and flows

- [ ] T-BR1-1 to T-BR1-4: one check-in per 8 hours, score 1 to 5 (automated)
- [ ] T-BR2-1 to T-BR2-5: handle format, hashed token, retry on handle clash, token format (automated)
- [ ] T-BR3-1 to T-BR3-5: post and reply length, non-clickable links, 5 per hour (automated)
- [ ] T-BR4-1: score 5 triggers the SOS drawer (automated)
- [ ] T-BR5-1 to T-BR5-3: account deletion purges check-ins and reassigns posts to Ghost-User (automated)

- [ ] T-AUTH-1 to T-AUTH-8: password rule, email verification, 14-day session, rate limit message, reset link (automated)
- [ ] T-NAV-1 to T-NAV-4: navigation rules (automated)
- [ ] T-E2E-1: Flow 1, sign up and first check-in (automated)
- [ ] T-E2E-2: Flow 2, post a debrief in a Peer Circle (automated)
- [ ] T-E2E-3: Flow 3, one-tap emergency SOS (automated)

Database, permissions and components

- [ ] T-DB-1 to T-DB-17: tables, constraints, triggers, view, seed (automated)
- [ ] T-SEC-1a to T-SEC-17b: every permission rule has an allow and a deny test (automated)
- [ ] T-C-1 to T-C-13, T-M1-1, T-M1-2, T-M2-1 to T-M2-3: components and modals (automated)
- [ ] T-S1-1 to T-S1-3, T-S2-1, T-S2-2, T-S3-1, T-S4-1, T-S5-1, T-S5-2, T-S6-1 to T-S6-6, T-S7-1 to T-S7-3, T-S8-1 to T-S8-3, T-S9-1, T-S9-2, T-S10-1, T-S10-2, T-S11-1 to T-S11-4, T-S12-1: screen states (automated)
- [ ] T-INT-1 to T-INT-3: profile, circles, feed operations (automated)

Quality and release

- [ ] T-NFR-1 to T-NFR-5, T-NFR-7: contrast, bundle size, touch targets, locale, offline, text size (automated)
- [ ] T-NFR-6: screens load within 2.5 seconds on throttled 3G (manual)
- [ ] T-NFR-8: contrast and keyboard focus check with WebAIM (manual)
- [ ] T-SEC-18 to T-SEC-21: server validation, no sensitive logs, secret scan, no secrets in the build (automated)
- [ ] T-REL-1 to T-REL-3: release readiness checks (automated)
- [ ] T-REL-4: demo script runs on the deployed app (manual)
- [ ] T-REL-5: hosted Supabase settings (manual)

16. Final release checklist

- [ ] All phases complete; every box in Sections 13 and 15 ticked.
- [ ] Full check passes on a clean install (fresh clone → install → reset database → full check).
- [ ] The deployed Vercel URL works, and the app installs and runs on a real phone as a PWA.
- [ ] Demo script (PRD 11.7) runs from start to finish without errors:
- Flow 1: sign up, verify email, log in, log a stress score of 3, see the toast on S6.
- Flow 2: open Peer Circles, open Nursing Debriefs, post a debrief, see it at the top of the feed.
- Flow 3: tap the red SOS button, see the SOS drawer, show the "Call SADAG Helpline" link.
- [ ] README explains:
- setup;
- every command;
- the test accounts;

- how to run the tests.
- [ ] `.env.example` lists every variable; a secret scan finds no keys in the repository or its history.
- [ ] Final comparison of the app against the PRD (acceptance criteria, screens, design) shows no gaps.

17. Progress log (the coding agent updates this)

Phase	Date	Status	Automated tests (passed / total)	Commit	Notes
1 Foundation	Not started	Not started	not run	none	Record the exact versions installed
2 Data and security	Not started	Not started	not run	none	
3 Accounts	Not started	Not started	not run	none	
4 Check-in and SOS	Not started	Not started	not run	none	
5 Peer Circles	Not started	Not started	not run	none	
6 Personal Wellness Log	Not started	Not started	not run	none	
7 Hardening	Not started	Not started	not run	none	
8 Release	Not started	Not started	not run	none	

18. Clarifications needed

All rows are Answered. Every answer is also written into PRD v1.1 (see PRD_v1.1_CHANGES.md) and its Change log. Questions 20 and 22 contain facts the author must confirm before submitting.

#	Question	Where (section / ID)	Answer	Status

1	The handle contains the role, but the sign-up form has no role field. How is the role chosen?	PRD S2, BR2	S2 gets a required Role dropdown (Nurse, Doctor, EMS). Admin is set only in the Supabase console.	Answered
2	F3 says users can reply and the notification opens "Post Details" (S12), but S12, a replies table and a reply story do not exist.	PRD F3, S8, 4.5, 10.1	Add S12 Post Detail, the `replies` table and story US8 (T-US8-1 to T-US8-3). Reply screen labels are in PRD v1.1: header "Debrief", box "Write a reply", button "Send Reply", empty text "No replies yet. Be the first to respond."	Answered
3	Key terms say a check-in captures "fatigue level", but S5 and the CheckIn table have none.	PRD 1.7, S5, 10.1	Remove "fatigue level". A check-in has stress score, shift type and an optional note only.	Answered
4	No message or rule text exists for a weak password.	PRD 5, S2, S4	Rule: at least 8 characters and 1 number. Message: "Password must be at least 8 characters and include 1 number." Success message after reset: "Password updated."	Answered
5	What is a "valid HPCSA/SANC token format"?	PRD 5, S2, US1	v1 checks format only: 6 to 12 letters or digits, no spaces or symbols. There is no live check against the HPCSA or SANC registers. Tokens are hashed on the server.	Answered
6	PRD 13.2 promises a post reporting button and keyword	PRD 13.2, 2.4	Deferred (Section 3.3). Moderation is done by an admin in the Supabase console. PRD 13.2 is	Answered

	flagging, but there is no screen, table or story.		updated.	
7	Stories and flows put Log Out and Delete Account on S10, but the inventory has them on S11. The feature table's story numbers do not match Section 6. The checklist says 12 screens.	PRD 4.1, 5, 6, 8.1, 15	S11 everywhere. Mapping: F1 US1, US2; F2 US3, US4; F3 US5, US8; F4 US4, US6; F5 US7. The screen count is 14 (S1 to S12, M1, M2).	Answered
8	The PRD gives different wording for the same message (invalid token: three versions; invalid log-in: two; consent checkbox: two; S1 offline banner dash).	PRD S2, S3, 12.2, 12.4	Use the acceptance-criteria wording: "Invalid professional token format. Use SANC/HPCSA number." and "Invalid email or password." The consent checkbox reads "I agree to the Privacy Policy and anonymous data handling under POPIA." Banner: "Offline mode — emergency crisis lines active". "You are offline. Log saved locally." is used for check-ins; "You are offline. Changes will sync when reconnected." is the general banner.	Answered
9	The User entity has an email, which Supabase Auth already stores.	PRD 10.1	Email is stored only in Supabase Auth. The `profiles` table has no email column.	Answered
10	Supabase has	PRD 5, S3	Use Supabase's built-in	Answered

	no per-account lock after 5 failed log-ins.		sign-in rate limit. When it triggers, show "Too many failed attempts. Try again in 15 mins". PRD 5 now says "after too many failed attempts".	
11	Supabase sessions do not expire after a set time.	PRD 5	The app signs the user out on start-up when the session is more than 14 days old (T-AUTH-3).	Answered
12	The PRD hashes tokens on the client, which makes the hash the thing that identifies a person and lets anyone craft requests.	PRD BR2, 12.3	Hash on the server inside the `signup` Edge Function. The app sends the token over HTTPS, the function hashes it and stores only the hash. The hash column cannot be read by app users.	Answered
13	"Email verification required before Peer Circles": what if the user is not verified?	PRD 5	Email confirmation is switched on in Supabase, so an unverified user cannot log in at all. They see "Please verify your email before logging in." There is no half-verified state.	Answered
14	How are the 18:00 reminder and reply notification shown, and what do the S11 "Notification Preferences" do?	PRD 4.5, S11	In-app only. The reminder is a banner on S6 at or after 18:00 SAST when no check-in exists for today. A reply alert is a row in `notifications` shown as a card on S6. Preferences are two switches (daily reminder, reply alerts), both on by default. Change Password sends the reset email link.	Answered
15	How are "daily streak" and the	PRD F5, S6	Streak = consecutive SAST calendar days with at least	Answered

	7-day chart defined?		one check-in, ending today or yesterday. The chart shows the last 7 SAST days, oldest first, using the day's highest score.	
16	"Active member count" needs data; G2 refers to a CircleMember table that does not exist.	PRD S7, G2	Active members = distinct authors of posts or replies in that circle in the last 30 days (view `circle_stats`). G2 is measured by posts and replies only in v1; "opening" a circle is not tracked.	Answered
17	Circle names differ between the screens and the data, and the rules for who may post are not stated.	PRD S7, 10.1, 11.4	Mapping in Section 8.1 (Nursing Debriefs = Nursing, Doctors Forum = Medical, EMS Emergency Room = EMS, General Wellness = General). Any signed-in clinician can read and post in any circle.	Answered
18	What rules apply to replies?	PRD BR3	Same rules as posts (10 to 1,000 characters, plain text, non-clickable links) and a separate limit of 5 replies per hour. Messages: "You have reached the limit of 5 posts per hour. Try again later." and "You have reached the limit of 5 replies per hour. Try again later."	Answered
19	How is "reassign author_id to Ghost-User" stored?	PRD BR5, 10.1	Ghost-User is a fixed system row in `profiles` (id all zeros, handle Ghost-User, role Ghost). `profiles.id` has no foreign key to Auth so this row can exist. Posts and replies also keep `author_handle`.	Answered
20	The PRD labels 0800 212 223	PRD M2, S10	Checked against sadag.org and news sources on 04	Answered

	"Healthcare EAP Crisis Line" and gives no numbers for Netcare Helpline or Legal Advisory.		Nov 2026: 0800 212 223 is a SADAG partner mental health helpline, not an employer EAP, so M2 card 2 is labelled "SADAG Mental Health Helpline (0800 212 223)". SADAG's Healthcare Workers Care Network line (0800 21 21 21) exists and could be added by the author. Netcare Helpline uses the Netcare 911 emergency number 082 911. EAP Services and Legal Advisory are information cards without a number. The author must confirm these before submitting.	
21	Is the SOS icon shown to logged-out users? Is the "SOS Crisis Banner" in BR4 a separate thing?	PRD M2, BR4, 8.3	SOS is on logged-in screens only (PRD M2 "Who can open"). The "SOS Crisis Banner" in BR4 is M2 with the care message.	Answered
22	Which tools does the plan use that are not named in the PRD?	PRD 11.1, 11.2	React Router, `vite-plugin-pwa`, `@fontsource/inter`, Lucide React, Vitest, React Testing Library, pgTAP, Playwright, ESLint. Email uses Supabase's built-in sender, which is rate limited on the hosted project, so demo accounts are created ahead of time. No other third-party service.	Answered
23	PRD 12.1 says "full offline support", but only some features can	PRD 12.1, 6.2	Offline means: the app shell, S10 with every crisis number, and one queued check-in. A queued check-in refused on sync (too	Answered

	work offline.		soon) is dropped with the restricted message. Reading and writing circles needs a connection. Post drafts are kept locally when a session expires.	
24	Which messages are missing from the PRD?	PRD 12.2	Added to PRD v1.1 12.2 (exact text in PRD_v1.1_CHANGES.md): password rule, rate limits, unverified email, "Password updated.", "No replies yet. Be the first to respond.", and the restricted banner as "Next check-in available in N hours." ("1 hour" when N is 1).	Answered
25	There is no age field but the minimum age is 18.	PRD 5	No age field. A valid professional registration token and the POPIA consent are the only gates; the privacy page states that the app is for registered adult practitioners.	Answered
26	PRD 11.6 (folder structure) and 11.7 (demo script, test tools) are missing.	Template, PRD 11	Folder structure is Section 5, test tools are Section 4.1, and the demo script is the three PRD flows (Section 16). Added to PRD v1.1.	Answered
27	Which colours cover white surfaces, text on primary and the toast?	PRD 9.1	`color.surface` #FFFFFF, `color.onPrimary` #FFFFFF, toast background = `color.text`, borders = `color.accent`. No other colours.	Answered
28	The consent checkbox mentions a Privacy Policy, but there is no	PRD 12.4	The label links to a static page `public/privacy.html` whose text the author writes (it names the EU storage region and that the	Answered

	policy screen. Data is stored in the EU region.	app is for registered adult practitioners). It is not an app screen.

19. Change log

Plan version	Date	What changed	Why
v1.0	04 Nov 2026	First version	Generated from PRD v1.1 (PRD v1.0 plus the 28 answers in Section 18)